Center for Internet Security®

CIS Benchmarks™

CIS Tencent Cloud Foundation Benchmark

v1.0.0 - 11-12-2025

Terms of Use

Please see the below link for our current terms of use:

https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is ***NEVER*** acceptable to host a CIS Benchmark in ***ANY*** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use *1*

Table of Contents *2*

Overview *6*

Important Usage Information **6**

Key Stakeholders **6**

Apply the Correct Version of a Benchmark **7**

Exceptions **7**

Remediation **8**

Summary **8**

Target Technology Details **9**

Intended Audience **9**

Consensus Guidance **10**

Typographical Conventions **11**

Recommendation Definitions *12*

Title **12**

Assessment Status **12**

Automated **12**

Manual **12**

Profile **12**

Description **12**

Rationale Statement **12**

Impact Statement **13**

Audit Procedure **13**

Remediation Procedure **13**

Default Value **13**

References **13**

CIS Critical Security Controls® (CIS Controls®) **13**

Additional Information **13**

Profile Definitions **14**

Acknowledgements **15**

Recommendations *16*

1 Identity and Access Management **16**

1.1 Avoid the use of the "root" account (Manual) 17

1.2 Ensure no root account access key exists (Manual) 19

1.3 Ensure Multi-factor Authentication is enabled for the "root" account (Manual) 21

1.4 Ensure that multi-factor authentication is enabled for all CAM users that have a console password (Manual) 23
1.5 Ensure users not logged on for 90 days or longer are disabled for console logon (Manual) 25
1.6 Ensure access keys are rotated every 90 days or less (Manual) 27
1.7 Ensure CAM password policy requires at least one uppercase letter (Manual) 29
1.8 Ensure CAM password policy requires at least one lowercase letter (Manual) 31
1.9 Ensure CAM password policy require at least one special character (Manual) 33
1.10 Ensure CAM password policy require at least one digit (Manual) 35
1.11 Ensure CAM password policy requires minimum length of 14 or greater (Manual) 37
1.12 Ensure CAM password policy prevents password reuse (Automated) 39
1.13 Ensure CAM password policy expires passwords in 365 days (Manual) 41
1.14 Ensure CAM password policy temporarily blocks logon after 5 incorrect logon attempts within an hour (Automated) 43
1.15 Ensure CAM policies that allow full "*:*" administrative privileges are not created (Manual) 45
1.16 Ensure CAM policies are attached only to groups or roles (Manual) 47

2 Logging and Monitoring 49
2.1 Ensure that CloudAudit is configured to export all operational log records (Manual) 50
2.2 Ensure the COS used to store CloudAudit logs is not publicly accessible (Manual) 52
2.3 Ensure audit logs for multiple cloud resources are integrated with Cloud Log Service (Manual) 54
2.4 Ensure virtual network flow log service is enabled (Manual) 57
2.5 Ensure EdgeOne log service is enabled (Manual) 59
2.6 Ensure Web Application Firewall access and security log service is enabled (Manual) 61
2.7 Ensure Cloud Firewall access and security log service is enabled (Manual) 64
2.8 Ensure Cloud Security Center Cloud Firewall, Web Application Firewall and Host Security log analysis is enabled (Manual) 66
2.9 Ensure log monitoring and alerts are set up for CAM Role changes (Manual) 69
2.10 Ensure log monitoring and alerts are set up for Cloud Firewall changes (Manual) 72
2.11 Ensure log monitoring and alerts are set up for VPC network route changes (Manual) 75
2.12 Ensure log monitoring and alerts are set up for VPC changes (Manual) 78
2.13 Ensure log monitoring and alerts are set up for COS permission changes (Manual) 81
2.14 Ensure log monitoring and alerts are set up for CDB instance configuration changes (Manual) 84
2.15 Ensure a log monitoring and alerts are set up to monitor Management Console sign-in without MFA (Manual) 87
2.16 Ensure a log monitoring and alerts are set up to monitor the usage of "root" account (Manual) 90
2.17 Ensure a log monitoring and alerts are set up to monitor disabling or deletion of customer created CMKs (Manual) 93
2.18 Ensure a log monitoring and alerts are set up to monitor COS bucket policy changes (Manual) 96
2.19 Ensure a log monitoring and alerts are set up to monitor security group changes (Manual) 100
2.20 Ensure that Logstore data retention period is set 365 days or greater (Automated) 103

3 Networking 105
3.1 Ensure that remote access is restricted from the internet (Manual) 106
3.2 Ensure virtual network flow log service is enabled (Manual) 108
3.3 Ensure routing tables for VPC peering are "least access" (Manual) 110
3.4 Ensure the security groups are configured with fine grained rules (Manual) 112
3.5 Ensure no security groups allow ingress from 0.0.0.0/0 to port 22 (Manual) 114
3.6 Ensure no security groups allow ingress from 0.0.0.0/0 to port 3389 (Manual) 116
3.7 Ensure a Cloud Load Balancer security group is created to isolate public network traffic. (Manual) 118

4 Storage 120
4.1 Ensure that COS bucket is not anonymously or publicly accessible (Automated) 121
4.2 Ensure that there are no publicly accessible objects in storage buckets (Manual) 124
4.3 Ensure that logging is enabled for COS buckets (Automated) 126
4.4 Ensure that 'Secure transfer required' is set to 'Enabled' (Automated) 128
4.5 Ensure network access rules for COS buckets are not set to publicly accessible (Automated) 130
4.6 Ensure server-side encryption is set to SSE-COS (Manual) 132
4.7 Ensure server-side encryption is set to SSE-KMS (Manual) 134
4.8 Ensure that 'Unattached disks' are encrypted (Manual) 136
4.9 Ensure that ‘Virtual Machine's disk’ are encrypted (Manual) 138

5 Relational Database TencentDB for MySQL 141
5.1 Ensure TencentDB for MySQL instance requires all incoming connections to use SSL (Automated) 142
5.2 Ensure TencentDB for MySQL instance does not allow public access (Automated) 144
5.3 Ensure the ‘Audit Function’ for TencentDB for MySQL instance is set to ‘Enabled’ (Automated) 147
5.4 Ensure 'Auditing Retention’ for TencentDB for MySQL instance is greater than 6 months (Automated) 149
5.5 Ensure TencentDB for MySQL instance has TDE (Transparent Data Encryption) set to ‘Enabled’ (Manual) 151
5.6 Ensure the TDE (Transparent Data Encryption) protector of theTencentDB for MySQL instance uses BYOK (Bring Your Own Key) encryption (Automated) 153

6 Kubernetes Engine 155
6.1 Ensure Cluster Audit is set to ‘Enabled’ on Kubernetes Engine Clusters (Automated) 156
6.2 Ensure Cloud Monitoring is set to Enabled on Kubernetes Engine Clusters (Automated) 158
6.3 Ensure role-based access control (RBAC) authorization is Enabled on Kubernetes Engine Clusters (Automated) 160
6.4 Ensure Cluster Health Check triggered at least once per week for Kubernetes Clusters (Automated) 162
6.5 Ensure Kubernetes web UI / Dashboard is not enabled (Automated) 164
6.6 Ensure Basic Authentication is not ‘Enabled’ on Kubernetes Engine Clusters (Automated) 166
6.7 Ensure Network policy is ‘Enabled’ on Kubernetes Engine Clusters (Manual) 168
6.8 Ensure VPC-CNI Mode support for Kubernetes Cluster (Automated) 170
6.9 Ensure Kubernetes Cluster Internet Access is not ‘Enabled’ (Automated) 172

7 Cloud Security Center 174
7.1 Ensure Cloud Security Center is Premium, Enterprise or Ultimate Edition (Manual) 175
7.2 Ensure cloud API exception monitoring is enabled (Manual) 177
7.3 Ensure member accounts are linked to a group account (Manual) 179
7.4 Ensure periodic security check tasks are configured (Manual) 181
7.5 Ensure notification is enabled for high-risk security activities (Manual) 183
7.6 Ensure log storage analysis is enabled (Manual) 185

8 Cloud Workload Protection Platform 187
8.1 Ensure CVM server has installed Cloud Workload Protection Platform(CWPP) Agent (Automated) 188
8.2 Ensure CVM server has installed the Cloud Workload Protection Platform(CWPP) Professional or Ultimate edition agent (Automated) 190
8.3 Ensure that the Cloud Workload Protection Platform(CWPP) application protection switch is ‘Turn on’ (Manual) 192
8.4 Ensure CWPP agent ‘self-protection’, ‘scheduled scanning’, and ‘automatic defense’ are ‘Enabled’ (Manual) 194

8.5 Ensure notification is enabled for all high-risk security activities (Manual) 196
8.6 Ensure log storage analysis is enabled (Manual) 198

9 Tencent Container Security Service 200
9.1 Ensure Container Security protection is enabled for clusters and hosts (Automated) 201
9.2 Ensure Image Scan is Enabled (Manual) 203
9.3 Ensure TCSS application protection switch is 'Turn on' (Manual) 205
9.4 Ensure Container Asset has installed Container Security Agent (Manual) 207
9.5 Ensure Scheduled Image Scanning is Configured (Automated) 209
9.6 Ensure Automatic Cluster Check is ‘Enabled’ (Manual) 211
9.7 Ensure Vulnerability Scanning is enabled (Manual) 213
9.8 Ensure Baseline Cycle Detection is Enabled (Manual) 215
9.9 Ensure Virus Scanning is Enabled (Automated) 217
9.10 Ensure Mirror Interception policy is configured (Manual) 219
9.11 Ensure notification is enabled for all high-risk security activities (Manual) 221
9.12 Ensure log analysis is enabled (Manual) 223

Appendix: Summary Table 225

Appendix: CIS Controls v7 IG 1 Mapped Recommendations 232

Appendix: CIS Controls v7 IG 2 Mapped Recommendations 234

Appendix: CIS Controls v7 IG 3 Mapped Recommendations 238

Appendix: CIS Controls v7 Unmapped Recommendations 243

Appendix: CIS Controls v8 IG 1 Mapped Recommendations 244

Appendix: CIS Controls v8 IG 2 Mapped Recommendations 248

Appendix: CIS Controls v8 IG 3 Mapped Recommendations 253

Appendix: CIS Controls v8 Unmapped Recommendations 258

Appendix: Change History 259

Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

Important Usage Information

All Benchmarks are available free for non-commercial use from the CIS Website. They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- CIS Configuration Assessment Tool (CIS-CAT® Pro Assessor)
- CIS Benchmarks™ Certified 3rd Party Tooling

These tools make the hardening process much more scalable for large numbers of systems and applications.

NOTE: Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that ***ALL*** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.

- **Use the most recent version of a Benchmark**: This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

Remediation

CIS has developed Build Kits for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
  - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
  - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
  - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
  - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
  - When the initial deployment above is completes successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

NOTE: As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the CIS Website. All other formats of the CIS Benchmarks™ (MS Word, Excel, and Build Kits) are available for CIS SecureSuite® members.

CIS-CAT® Pro is also available to CIS SecureSuite® members.

Target Technology Details

This security configuration benchmark covers foundational elements of Tencent Cloud. The recommendations detailed here provides prescriptive guidance for configuring security options for a subset of Tencent Cloud services with an emphasis on foundational, testable, and architecture agnostic settings. Specific Tencent Cloud Services in scope for this document include:

- Cloud Access Management(CAM)
- Virtual Private Cloud (VPC)
- Cloud Object Storage(COS)
- TencentDB for MySQL
- Tencent Kubernetes Engine (TKE)
- Key Management Service (KMS)
- Cloud Load Balancer(CLB)
- Cloud Log Service(CLS)
- Cloud Block Storage(CBS)
- Cloud Audit (CA)
- Cloud Security Center(CSC)
- Cloud Workload Protection Platform(CWPP)
- Tencent Container Security Service(TCSS)
- Web Application Firewall(WAF)
- Cloud Firewall(CFW)
- TencentCloud EdgeOne(EO)

Intended Audience

This document is intended for system and application administrators, security specialists, auditors, help desk, platform deployment, and/or DevOps personnel who plan to develop, deploy, assess, or secure solutions in Alibaba Cloud services.

Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit https://workbench.cisecurity.org/.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
`Stylized Monospace font`	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
`Monospace font`	Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.
`<Monospace font in brackets>`	Text set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.
Bold font	Additional information or caveats things like **Notes**, **Warnings**, or **Cautions** (usually just the word itself and the rest of the text normal).

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) “5.1 - Establish Secure Configurations” and (v8) '4.1 - Establish and Maintain a Secure Configuration Process” so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

  Items in this profile intend to:

  - be practical and prudent;
  - provide security focused best practice hardening of a technology; and
  - limit impact to the utility of the technology beyond acceptable means.

- **Level 2**

  This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

  - are intended for environments or use cases where security is more critical than manageability and usability
  - acts as defense in depth measure
  - may impact the utility or performance of the technology
  - may include additional licensing, cost, or addition of third party software

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Contributor

- Bohao Zhang
- Changming Cheng
- Chen Liu
- Jiawei Peng
- Jing He
- Jun Wang
- Mike Wicks, Center for Internet Security, New York
- Phil White , Center for Internet Security, New York
- Shuqi Liu
- Wenran Han
- Woon Ming Thien
- Xi Wu
- Xiaoxiao Yu
- Xinhao Huang
- Yang Li
- Yizhen Jia
- Yuchen Mu
- Zhao Zhao

Recommendations

1 Identity and Access Management

This section contains recommendations for configuring identity and access management related options.

1.1 Avoid the use of the "root" account (Manual)

Profile Applicability:

- Level 1

Description:

The root account in Tencent Cloud (the initial account created during registration) should only be used for the minimal necessary operations. Ensure that the root account is not used for routine daily operations and administrative tasks within Tencent Cloud.

Rationale:

The root account is the initial account created during registration in Tencent Cloud which requires the owners' identity. This account holds unrestricted privileges across the Tencent Cloud platform, encompassing billing, service management, and user management. Any compromise or misuse of the root account poses significan risks to the entire cloud environment, potentially leading to accidental or intentional destructive actions.

Audit:

You can review CloudAudit logs for actions performed by the root account (i.e., the main account uin). In the Tencent Cloud Console, navigate to CloudAudit and identify operations performed by the root user.

Remediation:

Using the management Console:

1. Login in to CAM console
2. Create CAM users and groups.
3. Assign appropriate permissions via policies. Reserve root account access for critical operations only.

References:

1. https://www.tencentcloud.com/document/product/598/34899

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

1.2 Ensure no root account access key exists (Manual)

Profile Applicability:

- Level 1

Description:

Confirm that no programmatic access credentials (SecretId/SecretKey) are associated with the root account.

Rationale:

Access keys for the root account provide full programmatic access to all Tencent Cloud resources. If these keys are leaked, the entire cloud environment may be exposed to unauthorized access and exploitation. It is highly recommended that all access keys associated with the root account should not be generated.

Impact:

Programs that already use root account access keys may stop working if you disable or delete the access keys without replacing them with other CAM user access keys in your program.

Audit:

Perform the following to determine if the 'root' user account has access keys:

Using the management Console:

1. Login in to CAM console.
2. In the left-side navigation pane, click `Access Key`.
3. Review the list of access keys for the root account. Ensure list is empty.

Remediation:

Immediately delete any active access keys for the root account via the console.

Using the management Console:

1. Login in to CAM console.
2. In the left-side navigation pane, click `Access Key` to review the list of access keys for the root account.
3. Click `Disable` to disable any activated access keys (temporarily disable key - for those keys that may still be needed), and/or click `Delete` to delete them (deleted keys cannot be recovered).
4. Ensure that neither the access key is generated or activated.
5. Enforce a policy prohibiting the issuance of root account access keys.

Default Value:

By default, no access key is created for the root account.

References:

1. https://www.tencentcloud.com/document/product/598/34228

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

1.3 Ensure Multi-factor Authentication is enabled for the "root" account (Manual)

Profile Applicability:

- Level 1

Description:

Ensure that Multi-Factor Authentication (MFA) for the root account is enabled to enhance its security.

Rationale:

MFA introduces an additional authentication factor (such as OTP generation via a hardware or software device), significantly lowering the risk of unauthorized access in the event of password compromise.

Audit:

Using the management Console:

1. Login in to Account Center.
2. Click `Security Settings` in the left-side navigation bar.
3. Verify that the MFA device is bound to the root account by checking under `Basic Settings` > `MFA Device`.

Remediation:

Using the management Console to bind an MFA Device:

1. Login in to Account Center.
2. Click `Security Settings` in the left navigation bar.
3. Go to `Basic Settings` > `MFA Device` and click `Bind`.
4. Complete the identity authentication as prompted on the authentication window that pops up.
5. Select a binding method: `Virtual MFA Device` (for example, Google Authenticator or Microsoft Authenticator) or U2F Security Key (for example, Yubikey), and follow the on-screen instructions to proceed with the binding operation.
6. Click `Submit` to complete the binding of the MFA device.

References:

1. https://www.tencentcloud.com/document/product/598/10592

Additional Information:

At least one MFA device is required for root accounts registration.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.5 Require MFA for Administrative Access Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider.	●	●	●
v7	4.5 Use Multifactor Authentication For All Administrative Access Use multi-factor authentication and encrypted channels for all administrative account access.		●	●

1.4 Ensure that multi-factor authentication is enabled for all CAM users that have a console password (Manual)

Profile Applicability:

- Level 1

Description:

Mandate that all CAM users with access to the Console have multi-factor authentication (MFA) enabled.

Rationale:

Implementing MFA for all console users safeguards against risks posed by compromised login credentials and adds another layer of defense against unauthorized access.

Audit:

Using the management Console:

1. Login in to CAM console
2. Click `Users` > `User List`.
3. Inspect the “MFA Status” column for each user.

Remediation:

Using the management Console:

1. Login in to CAM console
2. Click `Users` > `User List`.
3. Inspect the “MFA Status” column for each user.
4. Click the `Username` with the MFA Status is `Not Enabled`.
5. In the User Details page, click 'security' > MFA Authentication Settings 'Manage' to Indetity Security page.
6. In Identity Security page, Step 1, Login Protection, select `Enable virtual MFA device verification`.
7. Click `OK` to save.
8. The user will be asked to bind MFA next time they log in.

Default Value:

MFA is enabled by default for CAM users

References:

1. https://www.tencentcloud.com/document/product/598/32657

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.		●	●
v7	16.3 Require Multi-factor Authentication Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.		●	●

1.5 Ensure users not logged on for 90 days or longer are disabled for console logon (Manual)

Profile Applicability:

- Level 1

Description:

Restrict CAM console login for any user account that has not authenticated for 90 days or more.

Rationale:

Inactive accounts are prime targets for attackers seeking to exploit forgotten or abandoned access points. Disabling them reduces the potential attack surface.

Audit:

Use the CAM console to generate a report from User Management. See each user's last login time. Or, query CloudAudit logs for user activity.

Using the CAM console:

1. Login in to CAM console
2. Click `Dashboard` > `Download user credential report`.
3. Check the `LastConsoleLoginTime` column to see if there are any time records older than 90 days.

Remediation:

In the User Management page, disable console access or delete stalled user accounts. Establish automated workflows to periodically review and address dormant accounts.

Using the CAM console:

1. Login in to CAM console
2. Click `Dashboard` > `Download user credential report`.
3. Check the `LastConsoleLoginTime` column to see if there are any time records older than 90 days.
4. Click `Users` > `User List`, select the `Username` who meet the above rule.
5. In the `Operation` column, click `More Actions` > `Disable` or `Delete` the user.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/598/61851

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.3 Disable Dormant Accounts Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.	●	●	●
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.		●	●
v7	16.9 Disable Dormant Accounts Automatically disable dormant accounts after a set period of inactivity.	●	●	●

1.6 Ensure access keys are rotated every 90 days or less (Manual)

Profile Applicability:

- Level 1

Description:

Implement a policy requiring the rotation of all CAM access keys (SecretId/SecretKey) at least every 90 days.

Rationale:

Regular rotation limits the exposure window of a potentially compromised key, and supports compliance with industry frameworks (such as ISO 27001).

Audit:

Perform the following to determine if access keys are rotated within 90 days:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User List`.
3. Click each `Username` > `API Key`, check the `Create time` that a key was created.
4. Make sure that no user has a key created earlier than 90 days ago.

Remediation:

Perform the following to disable and delete access keys:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User List` and click the username of the target CAM user.
3. Click `Username` > `API Key` > `Create Key` to create new AccessKey.
4. Click `OK` to create a new key for rotation.
5. Update all applications and systems to use the new AccessKey pair.
6. Disable the original AccessKey pair.
7. Confirm that your applications and systems are working.
8. Delete the original AccessKey pair.

References:

1. https://www.tencentcloud.com/document/product/598/34228

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	16 Account Monitoring and Control Account Monitoring and Control			

1.7 Ensure CAM password policy requires at least one uppercase letter (Manual)

Profile Applicability:

- Level 1

Description:

Enforce password policy standards requiring at least one uppercase letter in all CAM user passwords.

Rationale:

Password complexity, including uppercase characters, increases resistance against brute force and dictionary attacks.

Audit:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. Under the Password rule, ensure `Uppercase letters` is selected in the `At least contain setting`.

Remediation:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. In the Password rule > `At least contain` > Select `Uppercase letters`.
4. Click `Apply modification`.

Default Value:

Enabled in the default password policy.

References:

1. https://www.tencentcloud.com/document/product/598/32649

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

1.8 Ensure CAM password policy requires at least one lowercase letter (Manual)

Profile Applicability:

- Level 1

Description:

Enforce password policy standards requiring at least one lowercase letter in all CAM user passwords.

Rationale:

The use of mixed character cases increases overall password complexity, reducing predictability.

Audit:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. Under the Password rule, ensure `Lowercase letters` is selected in the `At least contain setting`.

Remediation:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. In the Password rule > `At least contain` > Select `Lowercase letters`.
4. Click `Apply modification`.

Default Value:

Enabled in the default password policy.

References:

1. https://www.tencentcloud.com/document/product/598/32649

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

1.9 Ensure CAM password policy require at least one special character (Manual)

Profile Applicability:

- Level 1

Description:

Requires at least one special character (e.g., !$%&) in all user passwords.

Rationale:

Special symbols increase password entropy and heighten defense against targeted guessing attacks.

Audit:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. Under the Password rule, ensure `Special characters (excluding space)` is selected in the `At least contain setting`.

Remediation:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. In the Password rule > `At least contain` > Select `Special characters (excluding space)`.
4. Click `Apply modification`.

Default Value:

Enabled in the default password policy.

References:

1. https://www.tencentcloud.com/document/product/598/32649

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

1.10 Ensure CAM password policy require at least one digit (Manual)

Profile Applicability:

- Level 1

Description:

Mandate the inclusion of numeric digits in user passwords.

Rationale:

Including numbers adds an additional layer of complexity to passwords

Audit:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. Under the Password rule, ensure `Digit` is selected in the `At least contain setting`.

Remediation:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. In the Password rule > `At least contain` > Select `Digit`.
4. Click `Apply modification`.

Default Value:

Enabled in the default password policy.

References:

1. https://www.tencentcloud.com/document/product/598/32649

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

1.11 Ensure CAM password policy requires minimum length of 14 or greater (Manual)

Profile Applicability:

- Level 1

Description:

Passwords are recommended to be configured to have a minimum length of no less than 14 characters.

Rationale:

Longer passwords are exponentially harder to compromise via brute force methods and align with leading security frameworks.

Audit:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. Under the Password rule, ensure that the value of `Minimum password length` is set between `14` and `32`.

Remediation:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. In the Password rule > `Minimum password length` > set between `14` and `32`.
4. Click `Apply modification`.

Default Value:

The default password policy requires a minimum of 8 characters for a password.

References:

1. https://www.tencentcloud.com/document/product/598/32649

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

1.12 Ensure CAM password policy prevents password reuse (Automated)

Profile Applicability:

- Level 1

Description:

Enable restrictions that prevent users from reusing a defined number of previous passwords.

Rationale:

Prevents cyclical or repeated password use, mitigating risks associated with credentials previously leaked or reused across systems.

Audit:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. Under the Password rule, ensure that the value of `Limitation on duplications` is set between `1` and `24`.

Remediation:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. In the Password rule > `Limitation on duplications` > set between `14` and `32`.
4. Click `Apply modification`.

Default Value:

The default password policy prevents reuse of the most recent password.

References:

1. https://www.tencentcloud.com/document/product/598/32649

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

1.13 Ensure CAM password policy expires passwords in 365 days (Manual)

Profile Applicability:

- Level 1

Description:

Configure user passwords to expire after a period not exceeding 365 days.

Rationale:

CAM password policies can require passwords to be expired after a given number of days. Mandating password changes at regular intervals decreases the probability of long-term credential compromise.

Audit:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. Under the Password rule, ensure that the value of `Periodically invalid` is set to `365` days or less.

Remediation:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. In the Password rule > `Periodically invalid` > set to `365` days or less.
4. Click `Apply modification`.

Default Value:

0 (no restrictions).

References:

1. https://www.tencentcloud.com/document/product/598/32649

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.14 Ensure CAM password policy temporarily blocks logon after 5 incorrect logon attempts within an hour (Automated)

Profile Applicability:

- Level 1

Description:

Enable account lockout to temporarily block user accounts after five consecutive unsuccessful login attempts within an hour.

Rationale:

Immediate lockout after repeated failures is an effective deterrent against brute-force and credential stuffing attacks.

Audit:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. Under the Password rule, ensure that the value of `Retry constraints` is set to `5`.

Remediation:

Using the management console:

1. Login in to CAM console.
2. Click `Users` > `User Settings`.
3. In the Password rule > `Retry constraints` > set to `5`.
4. Click `Apply modification`.

Default Value:

10 times/hour.

References:

1. https://www.tencentcloud.com/document/product/598/32649

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.15 Ensure CAM policies that allow full ":*" administrative privileges are not created (Manual)*

Profile Applicability:

- Level 1

Description:

Prohibit any policy creation that grants full administrative privileges.

Rationale:

Permissive "*:*" policies violate the principle of least privilege and dramatically increase organizational risk in the event of account compromise or administrative error. It is highly recommended to start with a minimum set of permissions and grant additional permissions as necessary.

Least privilege principle: granting only the permissions required to perform tasks. Determine what users need to do and then create policies with permissions only fits those tasks, instead of allowing full administrative privileges.

Audit:

Using the management console:

1. Login in to CAM console.
2. Click `Policies`.
3. In the Policy page, click `Custom Policy` .
4. Review custom policies and make sure that no policy has a statement that includes "Effect": `Allow`, "Action": `*`, and "Resource": `*`, or any policy with such statement is not attached to any CAM identities (including CAM users, user groups, or roles).

Remediation:

Using the management console:

1. Login in to CAM console.
2. Click `Policies`.
3. In the Policy page, click `Custom Policy` .
4. Click `Create a custom policy.` > `Create by policy builder`.
5. Review and modify any policy set with statements that includes "Effect": `Allow`, "Action": `*`, and "Resource" to the minimum necessary privileges.

References:

1. https://www.tencentcloud.com/document/product/598/35596

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4 Controlled Use of Administrative Privileges Controlled Use of Administrative Privileges			

1.16 Ensure CAM policies are attached only to groups or roles (Manual)

Profile Applicability:

- Level 1

Description:

Enforce policy that restricts assignment of permissions directly to individual users. Policies should be assigned to groups or roles instead.

Rationale:

Group-based and role-based assignments streamline permission management, make audits more efficient, and reduce the risk of excessive or outdated permissions.

Audit:

In the CAM Console, review policy assignment details and identify any policies linked directly to user accounts.

Alternatively, **Using the management console:**

1. Login in to CAM console.
2. Click `Users` > `User List`.
3. Click on each username under `User List`, `Username` > `Permissions` > `Permission Policy` , ensure no policy is selected.

Remediation:

Perform the following to create a CAM user group and assign a policy to it:

Using the management console:

1. Login in to CAM console.
2. Click `User Groups`.
3. Click `Create User Group` > set `User Group Name` > click `Next` > `Select the policy` to be attached > `Next` > `Completed`.
4. In User Group page, find the target "User Goup Name" , click `Group name` > click `Associate Policies` > `Select the policy` to be attached > click `OK`.
5. In User Groups page, find the target "User Goup Name" > click `Add user` > `Select the users to add` > click `OK`.

Perform the following to assign policies to user groups: **Using the management console:**

1. Login in to CAM console.
2. Click `Policies`.
3. On the Policies page, select the policy to be associated > click `Associate Users/Group/Role` in the Operation column.
4. In the `Associate Users/User Groups/Roles` pop-up window, switch to `User Group` in the Operation column and select the `user group` to associate with policy.
5. Click `OK` to complete the association.

References:

1. https://www.tencentcloud.com/document/product/598/32666
2. https://www.tencentcloud.com/document/product/598/10602

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

2 Logging and Monitoring

This section covers recommendations addressing Logging and Monitoring on Tencent Cloud.

2.1 Ensure that CloudAudit is configured to export all operational log records (Manual)

Profile Applicability:

- Level 1

Description:

CloudAudit is used to perform supervision, compliance check, operation review, and risk review for your Tencent Cloud account. It records logs, and monitors and records account activities associated with operations performed through Tencent Cloud console, APIs, command line tools, and other services in the Tencent Cloud infrastructure. The records will help you conduct security analysis, resource change tracking, and troubleshooting.

Rationale:

CloudAudit will be enabled when you create a Tencent Cloud account. An activity under your Tencent Cloud account will be recorded as an event by CloudAudit. You can view event records on the Operation Record page of the CloudAudit console. On this page, you can view and search for your Tencent Cloud account activities in the last 30 days. You can also create a CloudAudit tracking set to archive, analyze, and respond to changes in your Tencent Cloud resources. A tracking set is used to specify a COS bucket to store recorded events. You can create a tracking set via CloudAudit console or APIs.

Audit:

Perform the following to determine if CloudAudit is enabled for all regions:

Using the management Console:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation pane, you will be presented with a list of Tracking Set.
3. Ensure at least one `Tracking Set` has All in the Resource type and All in the Event Type.
4. Ensure `Shipping Location` is configured to export events to COS for storage.

Remediation:

Perform the following to enable all-resource-type CloudAudit logging:

Using the management Console:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation pane.
3. Click `Create` to create new Tracking Set.

   a. Enter a trail name in the `Tracking Set Name`.

   b. Set `Event Type` to `All` .

   c. In the Shipping Location, select `COS` under 'Ship the event to' setting and specify the COS (either existing buckets or to create a new bucket under the current account).

   d. In the Delivery location, select `Log Service CLS` and specify a CLS project name.

   e. Click `Creation Completed`.

Default Value:

By default, no Tracking set is configured.

References:

1. https://www.tencentcloud.com/document/product/1021/37598

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

2.2 Ensure the COS used to store CloudAudit logs is not publicly accessible (Manual)

Profile Applicability:

- Level 1

Description:

CloudAudit logs a record of every API call made in your Tencent Cloud account. These logs file are stored in a designated COS bucket. It is recommended that the access control list (ACL) of this COS bucket, which CloudAudit logs to, be configured to deny public access to prevent exposure of sensitive operational and security data.

Rationale:

Allowing public access to COS containing CloudAudit log content may aid an adversary in identifying weaknesses in the affected account's use or configuration.

Audit:

Perform the following to determine if any public access is granted to the COS bucket via an ACL:

Using the Management Console:

1. Login to CloudAudit Console.
2. In the API activity history pane on the left, click `Trails`.
3. In the `Trails` pane, click the bucket names in the COS bucket column.
4. Log on to COS Console.
5. Click `Bucket List` in the left navigation bar.
6. Click on the designated `COS` bucket that is used to store CloudAudit logs the bucket and click `Configure`.
7. Click `Permission Management` > `Bucket Access Permissions` > Ensure `Private Read and Write` is configured for COS bucket.

Remediation:

Perform the following to remove any public access that has been granted to the bucket via an ACL:

Using the Management Console:

1. Log on to COS Console.
2. Click `Bucket List` in the left navigation bar.
3. Click on the designated `COS` bucket that is used to store CloudAudit logs the bucket and click `Configure`.
4. Under `Permission Management` > `Bucket ACL` > select `Private Read and Write`.
5. Click `Save`.

Default Value:

Private Read/Write.

References:

1. https://www.tencentcloud.com/document/product/436/12470

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v8	8.11 Conduct Audit Log Reviews Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.		●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

2.3 Ensure audit logs for multiple cloud resources are integrated with Cloud Log Service (Manual)

Profile Applicability:

- Level 1

Description:

Tencent Cloud Log Service (CLS) provides log collection and real-time analysis across multiple cloud resources. By integrating logs from different sources, enterprises can achieve large-scale security governance and monitor all their resources. CLS supports log collection from the following sources:

- CloudAudit: Records all API calls made within a Tencent Cloud account, including user identity, request time, API operations, request parameters, response content, and other details. This facilitates operation audits, risk tracking, and security monitoring.
- MySQL : Records database operation logs, covering all Data Manipulation Language (DML) and Data Definition Language (DDL) operations. Log fields include executed SQL statements, operation types, operation times, database names, table names, user information, and more. With minimal impact on system performance, this enables users in auditing database operations and enhancing database security.
- COS : Records detailed information on all COS interactions, including operation types (such as upload, download, file deletion), access times, requested storage buckets, requested file names, visitor IP addresses, request results, and more, providing users with a comprehensive view of COS access and operations.
- CLB : Records detailed information about all HTTP(S) traffic, including request times, client IPs, request URIs, request methods, response times, backend server addresses, response status codes, and request/response byte counts. These logs enable monitoring of traffic conditions, server health, and request handling.
- API Gateway: Records detailed access logs for each API request, including API name, caller IP address, request method, requested URL, response status code, response/byte counts, and response time. These logs enable monitoring of API performance, request analysis, and usage tracking.

These logs can be centrally collected and stored in Tencent Cloud Log Service (CLS), supporting real-time analysis, alert configuration, and dashboard visualization to help users to continuously monitor and audit their cloud resources.

Rationale:

After sending the audit logs to CLS, real-time and historical activity records based on users, APIs, resources, and IP addresses can be generated. This allows logs from multiple cloud products to be centrally collected in CLS, supporting the creation of alert and notification mechanisms to quickly detect anomalies or sensitive records.Additionally, the log retention period can be extended to 180 days.

Audit:

Perform the following to ensure the logs are integrated with CLoud Log Services:

1. In the CLS cloud product access list, find the operation guidelines for the cloud products that need to deliver logs.
2. Log in to the respective cloud product console and follow the guidelines to enable log delivery to CLS.
3. After enabling log delivery to CLS, go to the CLS console to view the detailed logs.

Remediation:

Perform the following to ensure the logs are integrated with CLoud Log Services:

1. Log in to the CLS console.
2. Click `Log Topic` on the left sidebar > Log Topic.
3. Check the corresponding log topic for the logs delivered by the respective product. The cloud product label will appear on the right of the Log Topic name.
4. Click on the target `Log Topic name` to see the detailed content of the cloud product's log topic. To change the `retention period`, click `Edit` under the Operation column.
5. Under `Log retention policy` > `Storage Period` > configure the log retention duration.
6. Click `OK` to save the modifications.

Default Value:

Not enabled.

References:

1. https://www.tencentcloud.com/document/product/614/38200

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.9 Centralize Audit Logs Centralize, to the extent possible, audit log collection and retention across enterprise assets.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.5 Central Log Management Ensure that appropriate logs are being aggregated to a central log management system for analysis and review.		●	●

2.4 Ensure virtual network flow log service is enabled (Manual)

Profile Applicability:

- Level 1

Description:

Tencent Cloud Flow Logs (FL) provide continuous and non-intrusive traffic collection service, enabling real time storage and analysis of network traffic to facilitate and support troubleshooting, architecture optimization, security detection and compliance auditing. With FL, users will be able to build more stable, secure and intelligent.

You can create a network flow log to collect inbound and outbound traffic within a defined scope (for example, Elastic Network Interface Cards, NAT gateways, private networks, subnets, dedicated gateways, and cross-region Cloud Connect traffic). After creating a flow log, collected FL data can be viewed in Log Service (CLS) or visualized through the advanced analytics dashboard.

Rationale:

Flow logs provide continuous, non-intrusive traffic collection services. They can store and analyze collected network traffic in real time, making them suitable for scenarios such as troubleshooting, compliance auditing, architecture optimization, and security testing.

Impact:

The destination of log shipping may incur charges.

Audit:

Perform the following ensure the virtual network flow log is enabled:

1. Log in to the VPC Console.
2. Select `Flow Log` > `Flow Log` in the left navigation pane.
3. Select the `region` where the target flow log is located.
4. On the `Flow Log page`, ensure the target `flow log` and `log collection` are configured.

Remediation:

Perform the following ensure the virtual network flow log is enabled:

1. Log in to the VPC Console.
2. Select `Flow Log` > `Flow Log` in the left navigation pane.
3. Select the `region` where you want to create a flow log.
4. On the Flow Log page, click `Create`.
5. On the Create Flow Log page, follow the instructions to complete the configuration and click `OK`.

Default Value:

Logging is disabled.

References:

1. https://www.tencentcloud.com/document/product/682

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.5 Ensure EdgeOne log service is enabled (Manual)

Profile Applicability:

- Level 2

Description:

EdgeOne global availability zone nodes support detailed logging for feature modules such as L4/7 acceleration, web protection, and edge functions. These logs are collected and aggregated by the CLS module, making them available for users to perform troubleshooting, checking the impact of configuration updates, generating monitoring metrics, etc.

Rationale:

By integrating Edgeone access and security logs with Log Service, website traffic and security events can be collected, monitored, and queried in real-time, improving network security.

Impact:

Extra charge will incur.

Audit:

To verify that EdgeOne real-time log delivery service is enabled, follow these steps:

1. Log in to the EdgeOne Console, select your `site > Log Service > Real-time Logs`.
2. Check the delivery task list and confirm that the task `status` shows `"Shipping"`.

Remediation:

To use EdgeOne real-time log delivery service, perform the following operations:

1. Log in to the EdgeOne Console, select your `site`, then navigate to `Log Service > Real-time Logs`.
2. Click `Create Delivery Task`, select the `log source`, and ensure the specific domain is enabled.
3. Click `Next`, then fill in the_ custom log content_ to be delivered.
4. Click `Next` again to configure the `log delivery destination`.
5. Enter the *destination details* and click `Start Delivery`.

Default Value:

Disabled.

References:

1. https://www.tencentcloud.com/document/product/1145/61293

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.6 Ensure Web Application Firewall access and security log service is enabled (Manual)

Profile Applicability:

- Level 2

Description:

Tencent Cloud Web Application Firewall (WAF) Log Service collects and analyzes access logs and security attack logs for protected domains. It provides real-time querying, dashboard visualization, and threat analysis capabilities to help administrators monitor traffic patterns and attack trends.

Rationale:

Enabling WAF access and security logs allows the security team to promptly analyze website access behavior and attack characteristics, supporting the formulation of effective protection strategies.

Impact:

1. Additional costs will be incurred for access log storage (attack logs are free).
2. Enabling attack log delivery will incur log delivery fees.

Audit:

Perform these checks to confirm log service status:

1. Log in to Tencent Cloud WAF Console.

   Select `Security Operations` in the left navigation bar → `Attack Logs` → Verify logs display attack data (enabled by default).

2. Select `Security Operations` in the left navigation bar → `Access Logs` → For each protected domain:

   a. Check if `Access Log switch` is `Enabled`.

   b. Confirm `Log Delivery Status` shows active connection to CLS/Ckafka.

3. Check log storage capacity:

   → Go to `Log Package Management` → Verify Remaining Capacity > 10% of total purchased

Remediation:

If logs are disabled, follow these steps:

1. Enable Access Logs

   a. Log in WAF Console > `Security Operations` > `Access Logs`

   b. `Locate target domain` → `Toggle Access Log` switch `ON`

   c. Confirm `authorization popup` (allows WAF to write logs)

2. Configure `Log Shipping` (Required for Compliance)

   a. Go to `Access Logs/Attack Logs` > `Log Shipping`

   b. Select `Domain names` → Enable `Delivery to CLS` or `Delivery to Ckafka`

   c. `Configure` storage:

      - Retention Period: ≥180 days (Recommended for L2 Compliance)
      - Storage Size: Calculate based on traffic (1GB ≈ 200,000 requests)

3. Purchase Log Package (If Insufficient Capacity)

   a. In Log Package Management → Click "Buy Log Package"

   b. Select specifications:

      - Region: Same as WAF instance
      - Capacity: Start with 100GB (scalable)
      - Duration: 6-12 months

   c. Complete payment → Return to verify delivery status

Default Value:

- Attack Logs: Default Enabled, Free
- Access Logs: Default Disabled, Paid

References:

1. https://www.tencentcloud.com/document/product/627/35649
2. https://www.tencentcloud.com/document/product/627/35648

Additional Information:

Attack logging is enabled by default and requires no additional configuration. Ensure the target domain name is displayed in the domain selection box at the top. Select "Last 1 Hour" as the time range and verify that the logs are being generated as expected.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.7 Ensure Cloud Firewall access and security log service is enabled (Manual)

Profile Applicability:

- Level 2

Description:

Log Service collects and stores log entries of internet traffic, protected by Cloud Firewall, supporting real-time log query, analysis and visualization. The query results can be consolidated and displayed on centralized dashboards for easy monitoring.

Rationale:

Enabling Cloud Firewall logs in Log Service ensures collection and storage of inbound and outbound traffic in real time for timely analysis, reports, alarms and downstream computing interconnection. Coupled with centralized dashboard visualization, this provides clear insights into traffic patterns and potential threats, improving network security management.

Impact:

Extra charge will be incurred by enabling the log.

Audit:

Perform the following ensure the Cloud Firewall access and security log is enabled:

1. Logon to Cloud Firewall Console.
2. In the left-side navigation pane, select `Log Analysis`.
3. Ensure the `Log analysis` is `enabled`.
4. Ensure the `Log capacity usage` is not exhausted.

Remediation:

Perform the following ensure the Cloud Firewall access and security log is enabled:

1. Logon to Cloud Firewall Console.
2. In the left-side navigation pane, select `Log Analysis`.
3. Click Buy Now on the Log Analysis page.
4. Select your log storage capacity, and then click Buy now to complete the payment.
5. Go back to Log Analysis page on Cloud Firewall console. Ensure the `Log analysis` is `enabled`.

Default Value:

Logging is disabled.

References:

1. https://www.tencentcloud.com/document/product/1160/49862

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.8 Ensure Cloud Security Center Cloud Firewall, Web Application Firewall and Host Security log analysis is enabled (Manual)

Profile Applicability:

- Level 2

Description:

Log Service collects log entries of Cloud Security Center for Cloud Firewall Logs, Web Application Firewall Logs and Host Security Logs, with 11 subtypes, including

1. Cloud Firewall Logs

    a. Access Control Logs

    b. Zero Trust Protection Logs

    c. Intrusion Prevention Logs

    d. Traffic Logs

    e. Operation Logs

2. Web Application Firewall Logs

    a. Attack Logs

    b. Access Logs

3. Host Security Logs

    a. Intrusion Detection Logs

    b. Vulnerability Management Logs

    c. Advanced Defense Logs

    d. Client-Related Logs

The Log Service supports real-time log query and analysis over the logs mentioned above. The query results are centrally displayed in dashboards.

Rationale:

Enabling Cloud Security Center logs ensures collection and storage of Cloud Firewall Logs, Web Application Firewall Logs and Host Security Logs across relevant subtypes for real-time analysis, timely detection of threats, incident reporting and centralized monitoring through dashboards, allowing users to continuous monitor and enhance their security posture.

Impact:

Extra charge will be incurred by enabling the log.

Audit:

Perform the following to ensure the Cloud Firewall Logs, Web Application Firewall Logs and Host Security Logs are enabled:

1. Login to Cloud Security Center Console.
2. In the left-side navigation pane, Click `Log Analysis` in "System Configuration" to enter the `Log Analysis` page.
3. In the `Log Analysis` page, ensure the switch for the specific log type are turned on.
4. Ensure the `log volume usage indicator` is not exhausted.

Remediation:

Perform the following ensure the Cloud Firewall Logs, Web Application Firewall Logs and Host Security Logs are enabled:

1. Login to Cloud Security Center Console.
2. In the left-side navigation pane, Click `Log Analysis` in "System Configuration" to enter the `Log Analysis` page.
3. Click `Buy Now` on the log Analysis page.
4. On the `Purchase page`, select `Edition` and configure some other settings as needed.
5. Click `Purchase Now`.
6. In the `log Analysis` click `Activate log Analysis` to complete the authorization.
7. In the `log type` menu, check the log types to enable the log collection.

Default Value:

Logging is disabled.

References:

1. https://www.tencentcloud.com/document/product/1008/56708

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.9 Ensure log monitoring and alerts are set up for CAM Role changes (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended to configure metric filters and alarms to monitor Tencent Cloud Access Management (CAM) Role creation, deletion and updating activities.

Rationale:

CAM offers predefined and custom roles to enforce least-privilege access to resources. By leveraging Log Service to monitor CAM role lifecycle activities in real time, users can promptly identify any potential malicious actions, enhancing overall identity and access governance.

Audit:

Perform the following to ensure the log monitoring and alerts are set up for CAM Role Changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `CAM` in the `Resource type`,and include the following events: `CreateRole`, `UpdateAssumeRolePolicy`, `DeleteRole`, `AttachRolePolicy`, `DetachRolePolicy`.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
8. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the log topic ID of the log.
9. Check whether the alarm policy includes the following query statements.

```
eventName:(CreateRole OR UpdateAssumeRolePolicy OR DeleteRole OR
AttachRolePolicy OR DetachRolePolicy) AND resourceType:cam | select count(*)
as log_count limit 100
```

Remediation:

Perform the following to ensure the log monitoring and alerts are set up for CAM Role Changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `CAM`,and select `Event Name` to include : `CreateRole`, `UpdateAssumeRolePolicy`, `DeleteRole`, `AttachRolePolicy`, `DetachRolePolicy`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:(CreateRole OR UpdateAssumeRolePolicy OR DeleteRole OR
AttachRolePolicy OR DetachRolePolicy) AND resourceType:cam | select count(*)
as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not configured by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/1021/42145
3. https://www.tencentcloud.com/document/product/614/34239

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.10 Ensure log monitoring and alerts are set up for Cloud Firewall changes (Manual)

Profile Applicability:

- Level 2

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor any changes to Cloud Firewall rules.

Rationale:

Monitoring Cloud Firewall rule changes provides visibility into network access changes and helps detect any unauthorized or suspicious activities promptly. By enabling real-time alerts through Log Service, users can respond quickly to potential security incidents, maintaining stronger control over network traffic and overall cloud security posture.

Audit:

Perform the following to ensure the log monitoring and alerts are set up for Cloud Firewall rule changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `CFW` in the `Resource type`,and include the following events: CreateAcRules,ModifyAcRule,DeleteAcRule.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is configured to ship event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:(CreateAcRules OR ModifyAcRule OR DeleteAcRule) AND
resourceType:cfw | select count(*) as log_count limit 100
```

Remediation:

Perform the following to ensure the log monitoring and alerts are set up for Cloud Firewall rule changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `CFW`,and select `Event Name` to include: `CreateAcRules`, `ModifyAcRule`, `DeleteAcRule`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:(CreateAcRules OR ModifyAcRule OR DeleteAcRule) AND
resourceType:cfw | select count(*) as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/1021/42145
3. https://www.tencentcloud.com/document/product/614/34239

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.11 Ensure log monitoring and alerts are set up for VPC network route changes (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor changes to VPC network route.

Rationale:

VPC routes define the network paths between Tencent Cloud VPCs and external destinations. Monitoring changes to these routes enables timely detection of unauthorized or unexpected modifications, ensuring that all traffic flows through intended and secure paths, thereby enhancing network security and operational reliability.

Audit:

Perform the following to ensure log monitoring and alerts are set up for VPC network route changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `VPC` in the `Resource type`,and include the following events: CreateRoutes,ReplaceRoutes,DeleteRoutes,ModifyRouteTableAttribute,Disable Routes,EnableRoutes.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:(CreateRoutes OR ReplaceRoutes OR DeleteRoutes OR
ModifyRouteTableAttribute OR DisableRoutes OR EnableRoutes) AND
resourceType:vpc | select count(*) as log_count limit 100
```

Remediation:

Perform the following to ensure the log monitoring and alerts are set up for VPC network route changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `VPC`,and select `Event Name` to include: `CreateAcRules`, `ModifyAcRule`, `DeleteAcRule`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:(CreateRoutes OR ReplaceRoutes OR DeleteRoutes OR
ModifyRouteTableAttribute OR DisableRoutes OR EnableRoutes) AND
resourceType:vpc | select count(*) as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/1021/42145
3. https://www.tencentcloud.com/document/product/614/34239

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.12 Ensure log monitoring and alerts are set up for VPC changes (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor VPC changes.

Rationale:

Monitoring VPC changes helps ensure that network traffic flows as intended and that any unauthorized or unexpected modifications are detected promptly, minimizing potential impact on connectivity and operational stability.

Audit:

Perform the following to ensure the log monitoring and alerts are set up for VPC changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `VPC` in the `Resource type`,and include the following events: CreateVpc,DeleteVpc,ModifyVpcAttribute,AttachClassicLinkVpc,DetachClassicLinkVpc.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:(CreateVpc OR DeleteVpc OR ModifyVpcAttribute OR
AttachClassicLinkVpc OR DetachClassicLinkVpc) AND resourceType:vpc | select
count(*) as log_count limit 100
```

Remediation:

Perform the following to ensure the log monitoring and alerts are set up for VPC changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `VPC`,and select `Event Name` to include: `CreateVpc`, `DeleteVpc`, `ModifyVpcAttribute`, `AttachClassicLinkVpc`, `DetachClassicLinkVpc`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:(CreateVpc OR DeleteVpc OR ModifyVpcAttribute OR
AttachClassicLinkVpc OR DetachClassicLinkVpc) AND resourceType:vpc | select
count(*) as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/614/34239
3. https://www.tencentcloud.com/document/product/1021/42145
4. https://www.tencentcloud.com/document/product/1021/37598
5. https://www.tencentcloud.com/document/product/1021/40499

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.13 Ensure log monitoring and alerts are set up for COS permission changes (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor changes to COS bucket permissions.

Rationale:

Monitoring changes to COS bucket permissions help ensure that access to sensitive data is controlled and any unauthorized or unintended modifications are detected promptly. This enables timely remediation, reducing the risk of data exposure and strengthening overall cloud storage security.

Audit:

Perform the following to ensure log monitoring and alerts are set up for COS permission changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `COS` in the `Resource type`,and include the following events: PutBucketACL, GetBucketACL.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:(PutBucketACL OR GetBucketACL) AND resourceType:cos | select
count(*) as log_count limit 100
```

Remediation:

Perform the following to ensure log monitoring and alerts are set up for COS permission changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `COS`,and select `Event Name` to include: `PutBucketACL` , `GetBucketACL`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:(PutBucketACL OR GetBucketACL) AND resourceType:cos | select
count(*) as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/614/34239
3. https://www.tencentcloud.com/document/product/1021/42145
4. https://www.tencentcloud.com/document/product/1021/37598
5. https://www.tencentcloud.com/document/product/1021/40499

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.14 Ensure log monitoring and alerts are set up for CDB instance configuration changes (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor changes to CDB Instance configuration.

Rationale:

Monitoring changes to CDB Instance configuration enable timely detection of unauthorized or unintended modifications, helping to prevent misconfigurations that could impact database security, availability, or performance. This allows for prompt remediation and strengthens overall database governance.

Audit:

Perform the following to ensure the log monitoring and alerts are set up for CDB instance configuration changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `CDB` in the `Resource type`,and include the following events:`UpgradeDBInstanceEngineVersion`, `UpgradeDBInstance`, `ModifyDBInstanceReadOnlyStatus`, `ModifyDBInstanceVipVport`, `ModifyAccountPrivileges`, `ModifyBackupConfig`, `CreateBackup`, `DeleteBackup`.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:(UpgradeDBInstanceEngineVersion OR UpgradeDBInstance OR
ModifyDBInstanceReadOnlyStatus OR ModifyDBInstanceVipVport OR
ModifyAccountPrivileges OR ModifyBackupConfig OR CreateBackup OR
DeleteBackup) AND resourceType:cdb | select count(*) as log_count limit 100
```

Remediation:

Perform the following to ensure the log monitoring and alerts are set up for CDB instance configuration changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `CDB`,and select `Event Name` to include: `UpgradeDBInstanceEngineVersion`, `UpgradeDBInstance`, `ModifyDBInstanceReadOnlyStatus`, `ModifyDBInstanceVipVport`, `ModifyAccountPrivileges`, `ModifyBackupConfig`, `CreateBackup`, `DeleteBackup`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:(UpgradeDBInstanceEngineVersion OR UpgradeDBInstance OR
ModifyDBInstanceReadOnlyStatus OR ModifyDBInstanceVipVport OR
ModifyAccountPrivileges OR ModifyBackupConfig OR CreateBackup OR
DeleteBackup) AND resourceType:cdb | select count(*) as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/614/34239
3. https://www.tencentcloud.com/document/product/1021/42145
4. https://www.tencentcloud.com/document/product/1021/37598
5. https://www.tencentcloud.com/document/product/1021/40499

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.15 Ensure a log monitoring and alerts are set up to monitor Management Console sign-in without MFA (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor Management Console sign-ins that are not protected by multi-factor authentication (MFA).

Rationale:

Monitoring single-factor console logins improves visibility into accounts without MFA protection, enabling timely detection of potentially vulnerable access. This helps strengthen account security and reduces the risk of unauthorized access to Tencent Cloud resources.

Audit:

Perform the following to ensure log monitoring and alerts are set up to monitor Management Console sign-ins without MFA:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `ACCOUNT` in the `Resource type`,and include the following events: ConsoleLogin.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:ConsoleLogin AND resourceType:account AND mfa:0 | select count(*)
as log_count limit 100
```

Remediation:

Perform the following to ensure log monitoring and alerts are set up to monitor Management Console sign-ins without MFA:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `ACCOUNT`,and select `Event Name` to include: `ConsoleLogin`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:ConsoleLogin AND resourceType:account AND mfa:0 | select count(*)
as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/614/34239
3. https://www.tencentcloud.com/document/product/1021/42145
4. https://www.tencentcloud.com/document/product/1021/37598
5. https://www.tencentcloud.com/document/product/1021/40499

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.16 Ensure a log monitoring and alerts are set up to monitor the usage of "root" account (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor any usage of “root” account.

Rationale:

Monitoring root account usage provides visibility into actions performed by the fully privileged account and helps detect unauthorized or unnecessary use. This enables timely response, encourages the principle of least privilege, and reduces the risk associated with root-level access to Tencent Cloud resources.

Audit:

Perform the following to ensure log monitoring and alerts are set up to monitor usage of “root” account:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `ACCOUNT` in the `Resource type`,and include the following events: ConsoleLogin.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:ConsoleLogin AND resourceType:account AND userName:root | select
count(*) as log_count limit 100
```

Remediation:

Perform the following to ensure log monitoring and alerts are set up to monitor usage of "root" account:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `ACCOUNT`,and select `Event Name` to include: `ConsoleLogin`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:ConsoleLogin AND resourceType:account AND userName:root | select
count(*) as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/614/34239
3. https://www.tencentcloud.com/document/product/1021/42145
4. https://www.tencentcloud.com/document/product/1021/37598
5. https://www.tencentcloud.com/document/product/1021/40499

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	4.9 Log and Alert on Unsuccessful Administrative Account Login Configure systems to issue a log entry and alert on unsuccessful logins to an administrative account.		●	●

2.17 Ensure a log monitoring and alerts are set up to monitor disabling or deletion of customer created CMKs (Manual)

Profile Applicability:

- Level 2

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor the deletion or disabling of customer-created CMKs.

Rationale:

Monitoring changes to the state of customer-managed keys (CMKs) ensures timely detection of disabled or deleted keys. Since data encrypted with such keys becomes inaccessible, this monitoring helps prevent unintended data loss and supports secure key management practices.

Audit:

Perform the following to ensure log monitoring and alerts are set up to monitor changes to the state of CMKs：

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `KMS` in the `Resource type`,and include the following events: DisableKey,DeleteKey,ScheduleKeyDeletion.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:(DisableKey OR DeleteKey OR ScheduleKeyDeletion) AND
resourceType:kms | select count(*) as log_count limit 100
```

Remediation:

Perform the following to ensure log monitoring and alerts are set up to monitor changes to the state of CMKs :

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `KMS`,and select `Event Name` to include: `DisableKey`, `DeleteKey`, `ScheduleKeyDeletion`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:(DisableKey OR DeleteKey OR ScheduleKeyDeletion) AND
resourceType:kms | select count(*) as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/614/34239
3. https://www.tencentcloud.com/document/product/1021/42145
4. https://www.tencentcloud.com/document/product/1021/37598
5. https://www.tencentcloud.com/document/product/1021/40499

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.18 Ensure a log monitoring and alerts are set up to monitor COS bucket policy changes (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor changes to COS bucket policies.

Rationale:

Monitoring COS bucket policy changes provides visibility into modifications that could impact access controls. This enables timely detection and remediation of overly permissive or unauthorized policies, helping to protect sensitive data stored in COS buckets.

Audit:

Perform the following to ensure log monitoring and alerts are set up for COS bucket policy changes：

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `COS` in the `Resource type`,and include the following events: `PutBucketCORS`,`PutBucketEncryption`,`PutBucketLifecycle`, `PutBucketPolicy`, `PutBucketReplication`, `DeleteBucketCORS`, `DeleteBucketReplication`, `DeleteBucketPolicy`, `DeleteBucketLifecycle`, `DeleteBucketEncryption`.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:(PutBucketCORS OR PutBucketEncryption OR PutBucketLifecycle OR
PutBucketPolicy OR PutBucketReplication OR DeleteBucketCORS OR
DeleteBucketReplication OR DeleteBucketLifecycle OR DeleteBucketEncryption)
AND resourceType:cos | select count(*) as log_count limit 100
```

Remediation:

Perform the following to ensure log monitoring and alerts are set up for COS bucket policy changes：

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `COS`,and select `Event Name` to include:`PutBucketCORS`,`PutBucketEncryption`,`PutBucketLifecycle`, `PutBucketPolicy`, `PutBucketReplication`, `DeleteBucketCORS`, `DeleteBucketReplication`, `DeleteBucketPolicy`, `DeleteBucketLifecycle`, `DeleteBucketEncryption`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:(PutBucketCORS OR PutBucketEncryption OR PutBucketLifecycle OR
PutBucketPolicy OR PutBucketReplication OR DeleteBucketCORS OR
DeleteBucketReplication OR DeleteBucketLifecycle OR DeleteBucketEncryption)
AND resourceType:cos | select count(*) as log_count limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/614/34239
3. https://www.tencentcloud.com/document/product/1021/42145
4. https://www.tencentcloud.com/document/product/1021/37598
5. https://www.tencentcloud.com/document/product/1021/40499

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	14 Controlled Access Based on the Need to Know Controlled Access Based on the Need to Know			

2.19 Ensure a log monitoring and alerts are set up to monitor security group changes (Manual)

Profile Applicability:

- Level 2

Description:

It is recommended to configure metric filters and alarms in Log Service to monitor changes to Security Groups.

Rationale:

Monitoring Security Group changes helps ensure that resources and services are not unintentionally exposed, enabling timely detection and remediation of unauthorized or unintended modifications.

Audit:

Perform the following to ensure log monitoring and alerts are set up to monitor security group changes：

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar, you will be presented with a list of trails.
3. Ensure at least one `Tracking Set` has `VPC` in the `Resource type`,and include the following events: `CreateSecurityGroup`, `CreateSecurityGroupPolicies`, `ReplaceSecurityGroupPolicy`, `ModifySecurityGroupAttribute`, `ModifySecurityGroupPolicies`, `DeleteSecurityGroupPolicies`, `DeleteSecurityGroup`.
4. Click on a tracking set name in the `Name` column.
5. Make sure `Enable Logging` is `turned on` and `Shipping Location` is ship the event to CLS for storage.
6. Login to CLS Console.
7. Click "Log Topic" in the left navigation pane to ensure that the log has been delivered to the log topic.
8. Click `Monitoring Alarm` > `Alarm Policy` on the left navigation bar to enter the alarm policy list page.
9. Search for the `Alarm Policy` using the `Monitoring Object` ID in the search box at the top right. The Monitoring Object ID is the `Log topic` ID of the log.
10. Check whether the alarm policy includes the following query statements.

```
eventName:(CreateSecurityGroup OR CreateSecurityGroupPolicies OR
ReplaceSecurityGroupPolicy OR ModifySecurityGroupAttribute OR
ModifySecurityGroupPolicies OR DeleteSecurityGroupPolicies OR
DeleteSecurityGroup) AND resourceType:vpc | select count(*) as log_count
limit 100
```

Remediation:

Perform the following to ensure log monitoring and alerts are set up to monitor security group changes:

1. Login to CloudAudit Console.
2. Click on `Tracking Set` on the left navigation bar.
3. Click `Create`.

   a. Enter a `Tracking Set Name` in the Basic info box.

   b. Set "Resource Type" to `VPC`,and select `Event Name` to include:`CreateSecurityGroup`, `CreateSecurityGroupPolicies`, `ReplaceSecurityGroupPolicy`, `ModifySecurityGroupAttribute`, `ModifySecurityGroupPolicies`, `DeleteSecurityGroupPolicies`, `DeleteSecurityGroup`.

   c. In the `Shipping Location`, select Ship the event to `CLS` and specify a `Log Topic Name`.

   d. Click `Create completed`.

4. Login to CLS Console.
5. Click `Monitoring Alarm` >`Alarm Policy` in the left navigation pane.
6. Click `Create`.

   a. Enter a name in the "Alert Name" box.

   b. Select the `Log Topic` where the log is located in the `Monitoring Object`.

   c. enter the following query statements in the Query statement section.

```
eventName:(CreateSecurityGroup OR CreateSecurityGroupPolicies OR
ReplaceSecurityGroupPolicy OR ModifySecurityGroupAttribute OR
ModifySecurityGroupPolicies OR DeleteSecurityGroupPolicies OR
DeleteSecurityGroup) AND resourceType:vpc | select count(*) as log_count
limit 100
```

7. Set Alarm severtiy:`Alarm`, Query state:`Results` , `>` ,`0` as in `Trigger Condition`.
8. Click `OK`.

Default Value:

The monitoring dashboard and alert are not set by default.

References:

1. https://www.tencentcloud.com/document/product/614/39574
2. https://www.tencentcloud.com/document/product/614/34239
3. https://www.tencentcloud.com/document/product/1021/42145
4. https://www.tencentcloud.com/document/product/1021/37598
5. https://www.tencentcloud.com/document/product/1021/40499

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	4.8 Log and Alert on Changes to Administrative Group Membership Configure systems to issue a log entry and alert when an account is added to or removed from any group assigned administrative privileges.		●	●

2.20 Ensure that Logstore data retention period is set 365 days or greater (Automated)

Profile Applicability:

- Level 2

Description:

Configure Log Service logstore retention to a minimum of 365 days to meet compliance requirements and support long-term log analysis and troubleshooting.

Rationale:

Setting a retention period of 365 days or longer ensures:

- Compliance with regulatory requirements such as financial industry standards (typically mandating log retention for ≥6 months)
- Availability of complete log evidence for security incident investigations
- Support for multi-dimensional retrospective analysis of business anomalies

Audit:

Using the management console:

1. Log in to the CLS console.
2. Select `Log Topic` on the left sidebar to enter the Log Topic list page.
3. Check each log topic in the list to verify whether the `Retention Time` is greater than or equal to 365 days.

Using the TCCLI:

Run the following command to obtain the list of CLS log topics, then check whether the log retention period is >=365 days based on the Period parameter in TopicInfo.

```
tccli cls DescribeTopics --region <your topic region>
```

Remediation:

Using the management console:

1. Log in to the CLS console.
2. Select `Log Topic` on the left sidebar to enter the Log Topic list page.
3. Locate the log topics with a retention period of less than 365 days, click `Edit` to open the editing page.
4. Find the `Storage Period` configuration and modify it to 365 days.
5. Click `OK`.

Using the TCCLI:

Run the following command to get the topic list and check the topic retention period

```
tccli cls DescribeTopics --region <your topic region>
```

Run the following command to modify the log topic retention period to 365 days

```
tccli cls ModifyTopic --TopicId <your topicID> --Period 365
```

Default Value:

Not enabled.

References:

1. https://www.tencentcloud.com/document/product/614/34239

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v8	8.9 Centralize Audit Logs Centralize, to the extent possible, audit log collection and retention across enterprise assets.		●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●
v7	6.5 Central Log Management Ensure that appropriate logs are being aggregated to a central log management system for analysis and review.		●	●

3 Networking

This section covers recommendations addressing networking on Tencent Cloud.

3.1 Ensure that remote access is restricted from the internet (Manual)

Profile Applicability:

- Level 2

Description:

The security group has a stateful packet filtering function, which is used to set network access control for cloud servers, load balancing, cloud databases and other instances, to control the inbound and outbound traffic at the CVM instance level. To minimize exposure, it is recommended that the inbound rule should not allow unrestricted remote access. Access should only be limited to specific trusted IP ranges or managed through bastion hosts.

Rationale:

Limit unrestricted SSH and RDP access reduces attack surface by preventing unauthorized or brute-force attempts from the public internet.

Impact:

All SSH and RDP connections from outside the network to the target VPC(s) will be blocked. If legitimate business requirements necessitate external ssh access, specific trusted source IP(s) must be explicitly whitelisted in the security group or firewall rules to permit access to the relevant VPC resources.

Audit:

1. Log in to the VPC console.
2. Select `Security` > `Security Group` in the left navigation bar.
3. Select the security group associated with the instance and go to the details page to view the security group rules.
4. Ensure there are no rules with a `source IP of 0.0.0.0/0`, `port 22` or `port 3389`.

Remediation:

1. Log in to the VPC console.
2. Select `Security` > `Security Group` in the left navigation pane.
3. Select the security group `ID/NAME` you want to edit.
4. Enter a specific source IP range to configure security group rules.
5. Click `Save`.

Default Value:

When no rules are configured, the security group denies all access by default.

References:

1. https://www.tencentcloud.com/document/product/215/38750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●
v7	12.4 Deny Communication over Unauthorized Ports Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.	●	●	●

3.2 Ensure virtual network flow log service is enabled (Manual)

Profile Applicability:

- Level 1

Description:

You can create a network flow log to collect inbound and outbound traffic within a defined scope (for example, Elastic Network Interface Cards, NAT gateways, private networks, subnets, dedicated gateways, and cross-region Cloud Connect traffic). Once created, flow log data can be stored and analyzed in Log Service (CLS) for visualization through advanced analytics dashboards for monitoring and investigation.

Rationale:

Flow logs provide continuous, non-intrusive traffic visibility across Tencent Cloud networks. They support real-time traffic collection, storage and analysis, making them suitable for scenarios such as troubleshooting, compliance auditing, architecture optimization, and security testing.

Impact:

The destination of log shipping may incur charges

Audit:

Perform the following to check if virtual network flow logging is enabled :

1. Log in to the VPC console.
2. Select `Flow Log` > `Flow Log` in the left navigation bar.
3. Select the region for the target flow log
4. On the `Flow Log` page, ensure that the target flow log and log collection are configured.

Remediation:

Perform the following to enable virtual network flow logging:

1. Log in to the VPC console.
2. Select `Flow Log` > `Flow Log` in the left navigation bar.
3. Select the region where you want to create a flow log.
4. On the Flow Logs page, click `Create`.
5. On the Create Flow Log page, follow the instructions to complete the configuration and click `OK`.

Default Value:

Flow Log is disabled by default.

References:

1. https://www.tencentcloud.com/document/product/1145/61293

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	12.5 Configure Monitoring Systems to Record Network Packets Configure monitoring systems to record network packets passing through the boundary at each of the organization's network boundaries.		●	●

3.3 Ensure routing tables for VPC peering are "least access" (Manual)

Profile Applicability:

- Level 1

Description:

After a VPC is associated with a peering connection, it is necessary to add routing policies to direct traffic to the peering connection. By default, routing policy is empty. Users can configure routing policies as needed to enable communication between different network segments or different hosts in VPCs. The configuration of policies should follow the “principle of least access" to minimize unnecessary or unintended network intercommunication between business traffic.

Rationale:

Overly broad routing rules may expose sensitive traffic or enable lateral movements across VPCs. Restricting routes to the minimal subnets or hosts adheres to the principle of "least access", reducing the risk of data leakage, misrouting or unauthorized access.

Audit:

1. Log in to the VPC console.
2. Click `Peering Connections` on the right navigation bar.
3. Select the region of peering connections and cilick `Instance ID`.
4. In the revlevant routing policy module, check the existing routing policy configuration.

Remediation:

1. Log in to the VPC console.
2. Click `Route Tables` on the right to navigate to the VPC route tables management page.
3. Click the route table `ID/NAME` to access the route policy configuration page.
4. `Add` or `Delete` routing entries to ensure that the routing policies pointing to the peering connection interconnection adhere to the "least access" principle.

Default Value:

Routing policy is empty by default.

References:

1. https://www.tencentcloud.com/document/product/553

Additional Information:

Peering connections only support intercommunication between VPCs in the same region. For cross-region requirements, you can choose Cloud Connect Network (CCN) product.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

3.4 Ensure the security groups are configured with fine grained rules (Manual)

Profile Applicability:

- Level 1

Description:

Security groups have stateful packet filtering capabilities to control inbound and outbound traffic for resources such as cloud servers, load balancers, cloud databases, and other instances. It is recommended that all security groups be configured with fine-grained rules to minimize exposure.

Rationale:

Configuring fine-grained rules can effectively reduce security risks by ensuring IP addresses outside the rules cannot access the cloud resources.

Audit:

1. Log in to the VPC console.
2. Select `Security` > `Security Group` in the left navigation bar.
3. Select the security group associated with the instance and view the security group rules on the details page.
4. Ensure that the rules in each security group are required for your operation.

Remediation:

1. Log in to the VPC console.
2. Select `Security` > `Security Group` in the left navigation bar.
3. Select the security group associated with the instance and view the security group rules on the details page.
4. `Delete` any unnecessary rules from the security group.

Default Value:

When no rules are configured, the security group denies all access by default.

References:

1. https://cloud.tencent.com/document/product/215/20089

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●
v7	12.4 Deny Communication over Unauthorized Ports Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.	●	●	●

3.5 Ensure no security groups allow ingress from 0.0.0.0/0 to port 22 (Manual)

Profile Applicability:

- Level 2

Description:

Security groups have stateful packet filtering capabilities to control inbound and outbound traffic for resources such as cloud servers, load balancers, cloud databases, and other instances. It is recommended that the inbound rule should not allow unrestricted access to port 22. Access should only be limited to specific trusted IP ranges or managed through bastion hosts.

Rationale:

Limit unrestricted SSH access reduces attack surface by preventing unauthorized or brute-force attempts.

Audit:

1. Log in to the VPC console.
2. Select `Security` > `Security Group` in the left navigation bar.
3. Select the security groups `ID/Name` associated with the instance and go to the details page to view the security group rules.
4. Ensure there are no rules with a `source IP of 0.0.0.0/0`, `port 22`.

- Note: Specifying a value of 'ALL' or a port range such as 0-1024 also includes port 22.

Remediation:

1. Log in to the VPC console.
2. Select `Security` > `Security Group` in the left navigation bar.
3. Select the security group you want to edit.
4. Enter a specific `source`,`Protocol:port` and `Policy` to configure security group rules.
5. Click `Save`.

Default Value:

When no rules are configured, the security group denies all access by default.

References:

1. https://www.tencentcloud.com/document/product/215/38750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●
v7	12.4 Deny Communication over Unauthorized Ports Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.	●	●	●

3.6 Ensure no security groups allow ingress from 0.0.0.0/0 to port 3389 (Manual)

Profile Applicability:

- Level 2

Description:

Security groups have stateful packet filtering capabilities to control inbound and outbound traffic for resources such as cloud servers, load balancers, cloud databases, and other instances. It is recommended that the inbound rule should not allow unrestricted access to port 3389. Access should only be limited to specific trusted IP ranges or managed through bastion hosts.

Rationale:

Limit unrestricted RDP access reduces attack surface by preventing unauthorized or brute-force attempts.

Audit:

1. Log in to the VPC console.
2. Select `Security` > `Security Group` in the left navigation bar.
3. Select the security groups `ID/Name` associated with the instance and go to the details page to view the security group rules.
4. Ensure there are no rules with a `source IP address of 0.0.0.0/0`, `port 3389`.

- Note: Specifying a value of 'ALL' or a port range such as 0-1024 also includes port 3389.

Remediation:

1. Log in to the VPC console.
2. Select `Security` > `Security Group` in the left navigation bar.
3. Select the security group you want to edit.
4. Enter a specific `source`,`Protocol:port` and `Policy` to configure security group rules.
5. Click `Save`.

Default Value:

When no rules are configured, the security group denies all access by default.

References:

1. https://www.tencentcloud.com/document/product/215/38750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●
v7	12.4 Deny Communication over Unauthorized Ports Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.	●	●	●

3.7 Ensure a Cloud Load Balancer security group is created to isolate public network traffic. (Manual)

Profile Applicability:

- Level 2

Description:

A security group acts as a virtual firewall that provides stateful data packet filtering and controls inbound and outbound traffic at the instance level. It is recommended that a dedicated security group be configured for Cloud Load Balancer (CLB) instances to isolate and control public network traffic.

Rationale:

Configuring a dedicated CLB security group after creation of CLB instance helps to ensure only trusted and necessary traffic is permitted, thereby reducing the attack surface and preventing unauthorized access to user's backend cloud resources.

Audit:

Using the management console:

1. Log in to the CLB Console.
2. In the left navigation bar, click `Instance list`. On the "Instance Management" page, click the `ID/Name` of the target CLB instance.
3. On the instance details page, click the `Security groups` tab.
4. On the Bound Security Groups page, check whether the secrity group has been bound.

Remediation:

Using the management console:

1. Log in to the Security Group Console to configure a security group rule.
2. In the left navigation bar, click `Security` > `Security Groups`.
3. Click `Create` > `OK`.
4. Click the `ID/Name` of the newly created security group and configure the `Inbound rules` for the security group as needed, including the `Source`, `Protocol:port`, `Policy`, and the order of the rules.
5. Log in to the CLB Console.
6. In the left navigation bar, click `Instance list`. On the "Instance Management" page, click the `ID/Name` of the target CLB instance.
7. On the instance details page, click the `Security groups` tab and click `Configuration` in the Bind Security Groups module.
8. In the Configure Security Group window that pops up, select the security group from `ID/Name` to be the CLB instance and click `OK`.

Default Value:

By default, no CLB security group is configured.

References:

1. https://www.tencentcloud.com/zh/document/product/214/14733
2. https://www.tencentcloud.com/zh/document/product/215/38750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	11 Secure Configuration for Network Devices, such as Firewalls, Routers and Switches Secure Configuration for Network Devices, such as Firewalls, Routers and Switches			

4 Storage

This section covers recommendations addressing storage on Tencent Cloud.

4.1 Ensure that COS bucket is not anonymously or publicly accessible (Automated)

Profile Applicability:

- Level 1

Description:

Cloud Object Storage (COS) uses buckets as containers to store objects. Each object is associated with a bucket, where access is managed through ACLs and bucket policies. It is recommended that COS buckets are not configured to allow anonymous and/or public access.

Rationale:

Allowing anonymous and/or public access permits anyone to read and/or modify bucket content, which may expose sensitive or business-critical data. Restricting access ensures that only authorized accounts and identities can interact with COS buckets, thereby reducing the risk of data leakage or misuse.

Impact:

Buckets that are intentionally configured to allow anonymous and/or public access due to business requirements may be impacted.

Audit:

The anonymous or public access to COS bucket can be restricted through both Bucket Access Control List (ACL) and Bucket Policy.

Using the Bucket ACL:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click `Permission Management`.
4. Under `Bucket ACL(Access Control List)` section, ensure the Bucket ACL is set to `Private Read/Write`.

Using the Bucket Policy:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click `Permission Management`.
4. Under `Permission Policy Settings` section, ensure that when `Everyone (*)` is selected under `User` and `Allow` is not selected under `Effect`.

Remediation:

The anonymous or public access to COS bucket can be restricted through both Bucket ACL and Bucket Policy.

Using the Bucket ACL:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click `Permission Management`.
4. Under `Bucket ACL(Access Control List)` section, select `Private Read/Write`.
5. Click `Save`.

Using the Bucket Policy:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click `Permission Management`.
4. Under `Permission Policy Settings` section, if `Everyone (*)` is selected under `User` and `Allow` is selected under `Effect` in a strategy,`delete` the strategy.

Default Value:

Private Read/Write

References:

1. https://www.tencentcloud.com/document/product/436/13315

Additional Information:

To implement access restrictions on buckets, it is recommended to configure Bucket Policy rather than configuring Bucket ACL, considering the following general access control rules:

1. If the access control is configured through both Bucket Policy and Bucket ACL, the resulting permissions will be the combination of the “allowed” rules configured through Bucket Policy and Bucket ACL. For example, if the public read is enabled under Bucket ACL and certain IAM account is granted read and write access in the Bucket Policy, the effective permissions will be public read and write by certain IAM account.
2. If there is any conflict between the configuration of Bucket Policy and Bucket ACL, explicit “Deny” rules take precedence. For example, if the public read is selected under Bucket ACL and Everyone(*) is configured as Deny under Bucket Policy, the public access will be denied.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	12.4 Deny Communication over Unauthorized Ports Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.	●	●	●
v7	16 Account Monitoring and Control Account Monitoring and Control			

4.2 Ensure that there are no publicly accessible objects in storage buckets (Manual)

Profile Applicability:

- Level 1

Description:

Cloud Object Storage (COS) uses buckets as containers to store objects, and each object can have its own Access Control List (ACL) in addition to the bucket ACL. It is recommended that object-level ACLs are not configured to allow public access.

Rationale:

Allowing public access to objects allows anyone on the internet to access sensitive business data. Even if a bucket ACL does not allow public access, individual objects may still be publicly accessible if their ACLs allow public access. Hence it is important to check ACLs at both the bucket and object levels.

Impact:

Objects that are intentionally configured to allow public access due to business requirements may be impacted.

Audit:

Using the Management Console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `File List`.
4. Click on `Details` under `Operation` on a target object.
5. Ensure `Object AC`L is set to `Private Read/Write`.

Remediation:

Using the Management Console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `File List`.
4. Click on `Details` under `Operation` on a target object.
5. Click `Private Read/Writ`e under `Object ACL`.
6. Click `Save`.

Default Value:

By default, object ACLs are set to Inherit, with objects inheriting their permissions from the ACL of their residing bucket.

References:

1. https://www.tencentcloud.com/document/product/436/13327

Additional Information:

When an object ACL is set to Inherit, object permissions follow those of the residing bucket. If the bucket allows public access, the object will also be publicly accessible.

When an object ACL is set to Private Read/Write, object doesn't allow public access. Even If the bucket ACL allows public access, the object remains private.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	12.4 Deny Communication over Unauthorized Ports Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.	●	●	●
v7	13 Data Protection Data Protection			

4.3 Ensure that logging is enabled for COS buckets (Automated)

Profile Applicability:

- Level 1

Description:

COS Bucket Access Logging generates logs that contain access records for every request made to the COS bucket. Each access log entry includes details, such as the request type, the resources involved, and the timestamp of the request. It is recommended to enable bucket access logging on the COS bucket.

Rationale:

Enabling COS bucket logging on target COS bucket allows capturing of all events that affect objects within the bucket. Storing logs in a separate bucket ensure secure, auditable access to log data, which is critical for security monitoring and incident response.

Impact:

Extra cost for log storage may incur.

Audit:

Perform the following to ensure access logging is enabled in COS bucket:

Through the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click `Logging`.
4. Under Logging, ensure `Status` is set to `Enabled`.

Remediation:

Perform the following to enable access logging in COS bucket:

Through the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click `Logging`.
4. Under Logging, click `Edit`.
5. Configure bucket logging.Set `Status` to `Enabled`.
6. Select Destination Bucket from list.
7. Enter a `Path Prefix`.
8. Click `Save`.

Default Value:

Logging is disabled.

References:

1. https://www.tencentcloud.com/document/product/436/17040

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

4.4 Ensure that 'Secure transfer required' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1

Description:

Require that all access to COS buckets occurs over secure, encrypted connections to protect data in transit.

Rationale:

Enforcing secure transfer enhances the security of COS bucket by ensuring all requests to the storage account use encrypted channels (e.g. HTTPS). Any requests made over insecure protocol such as HTTP will be rejected, preventing potential interception or data leakage during transmission.

Audit:

Using the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `Permission Management`.
4. Under `Permission Policy Settings` section, ensure a policy is set to `Deny` (Effect), `All Actions` (Operation), and `secure-transport equals to false`(Condition).

Remediation:

USing the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `Permission Management`.
4. Under `Permission Policy Settings` section, click `Add Policy` to set a policy to `Deny` (Effect), `All Actions` (Operation), and `secure-transport equals to false` (Condition).

Default Value:

Not configured

References:

1. https://www.tencentcloud.com/document/product/436/46206#allowing-only-https-requests-(cos.3Asecure-transport)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

4.5 Ensure network access rules for COS buckets are not set to publicly accessible (Automated)

Profile Applicability:

- Level 2

Description:

By default, COS buckets accept connections from any network. Restricting network access to only specific VPCs or trusted IP addresses provides an additional layer of security.

Rationale:

Granting access only to specific VPCs or on-premises systems minimizes exposure to unauthorized or potentially malicious traffic from the public internet.

Audit:

Using the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `Permission Management`.
4. Under `Permission Policy Settings` section, ensure a policy is set to be granted to specific vpc or internet IP addresses.

Remediation:

Using the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `Permission Management`.
4. Under `Permission Policy Settings` section, add a policy which is set to `Deny` (Effect), `All Actions` (Operation), `IP equals to` specified `IP address` or `IP address segment` (Condition), and `vpcid equals to` specified `vpcid`(Condition).
5. Click on `Save`.

Default Value:

Not configured

References:

1. https://www.tencentcloud.com/document/product/436/46206

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

4.6 Ensure server-side encryption is set to SSE-COS (Manual)

Profile Applicability:

- Level 2

Description:

Require that all objects stored in COS buckets are protected with server-side encryption (SSE-COS) to ensure data at rest is secured.

NOTE: This recommendation is mutually exclusive for server-side encryption. Only 1 encryption method (SSE-COS or SSE-KMS) should be enabled per bucket.

Rationale:

Enabling SSE-COS protects data stored in COS buckets by automatically encrypting objects at rest. This reduces the risk of unauthorized access in the event of storage compromise, ensuring sensitive information remains secure.

Audit:

Perform the following to determine if SSE-COS is enabled:

Using the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `Secure Management`.
4. Under the `Server-side Encryption` section, ensure the target COS Bucket `Encryption` is set to `SSE-COS`.

Remediation:

Perform the following to configure SSE-COS:

Using the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `Secure Management`.
4. Under the `Server-side Encryption` section, click on edit.
5. Set `status` to `enable` and select `SSE-COS`.
6. Click `Save`.

Default Value:

Not encrypted.

References:

1. https://www.tencentcloud.com/document/product/436/18145

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

4.7 Ensure server-side encryption is set to SSE-KMS (Manual)

Profile Applicability:

- Level 2

Description:

Require that all objects stored in COS buckets are protected with server-side encryption (SSE-KMS) to ensure data at rest is secured.

NOTE: This recommendation is mutually exclusive for server-side encryption. Only 1 encryption method (SSE-COS or SSE-KMS) should be enabled per bucket.

Rationale:

Enabling SSE-KMS protects data stored in COS buckets by automatically encrypting objects at rest. This reduces the risk of unauthorized access in the event of storage compromise, ensuring sensitive information remains secure.

Impact:

Configuring SSE-KMS may incur additional costs for KMS service usage.

Audit:

Perform the following to determine if SSE-KMS is enabled:

Using the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `Secure Management`.
4. Under the `Server-side Encryption` section, ensure the target COS Bucket `Encryption` is set to `SSE-KMS`.

Remediation:

Perform the following to configure SSE-KMS :

Using the management console:

1. Logon to COS console.
2. In the `Bucket List` pane, click on a target COS bucket.
3. Click on `Secure Management`.
4. Under the `Server-side Encryption` section, click on `Edit`.
5. Set status to `enable` and select `SSE-KMS`. Specify the KMS key with `Default key` or `custom key` (BYOK).
6. Click `Save`.

Default Value:

Not encrypted.

References:

1. https://www.tencentcloud.com/document/product/436/18145

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

4.8 Ensure that 'Unattached disks' are encrypted (Manual)

Profile Applicability:

- Level 1

Description:

Ensure that unattached disks in a subscription are encrypted. This protects data at rest by automatically encrypting data stored on the disk and decrypting it when accessed.

Rationale:

Enabling encryption for unattached disks safeguards stored data against unauthorized access, even when the disks are not attached to a CVM instance. The encryption process is transparent, providing security without impacting normal operations.

Audit:

1. Logon to CVM Console.
2. In the left pane, click `Cloud Block Storage`.
3. Select `region` -> each Disk `ID/Name`.
4. Ensure that each disk has enpowered Encryption

Remediation:

1. Logon to CVM Console.
2. In the left pane, click `Cloud Block Storage`.
3. In the upper-left corner of the Disks page, click `Create` disk.
4. In the `Purchase Data Disk` dialog box, select `Advanced`, select the `Enable disk encryption` and then select a key from the drop-down list.

Default Value:

By default, CBS disks are not encrypted.

References:

1. https://www.tencentcloud.com/document/product/362/33139

Additional Information:

- Once an unencrypted disk is created, data can only be encrypted by manually copying it to a new encrypted disk. The encryption status of an existing disk cannot be changed from unencrypted to encrypted directly.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

4.9 Ensure that 'Virtual Machine's disk' are encrypted (Manual)

Profile Applicability:

- Level 1

Description:

Ensure that Cloud Virtual Machine (CVM) disks are encrypted during instance creation. This protects data at rest by automatically encrypting data as it is written to the disk and decrypting it when read.

Rationale:

Enabling disk encryption protects data at rest, mitigating the risk of unauthorized access in the event of storage compromise. The encryption process is transparent to applications, providing security without affecting normal operations.

Audit:

1. Logon to CVM Console.
2. In the left pane, click `Cloud Block Storage`.
3. Select `region` -> each Disk `ID/Name`.
4. Ensure that each disk has enabled Encryption

Remediation:

Encrypt a system disk when copying an image in the CVM console by performing the following steps:

1. Logon to CVM Console.
2. In the left-side navigation pane, choose `Images`.
3. In the top navigation bar, select a `region`.
4. On the Images page, click the `Custom Image` tab.
5. Select the target image and click `copy Image` in the `Actions` column.
6. In the `Copy Image` dialog box, check the `Encrypt box` and then select a key from the drop-down list.
7. Click `OK`.
8. Instances created from this encrypted image have encrypted system disks.

Encrypt a data disk when creating an instance by following steps:

1. Logon to CVM Console.
2. In the left-side navigation pane, choose `Instances`.
3. On the Instances page, click `Create` Instance.
4. On the Configurations page, find the `Storage` section and perform the following steps:

   a) Click `Add data disk`;

   b) Specify the disk category and capacity of data disk;

   c) Select `Disk Encryption` and then select a key from the drop-down list.

Default Value:

By default, CVM's disks are not encrypted.

References:

1. https://www.tencentcloud.com/document/product/362/33139

Additional Information:

Once an unencrypted disk is created, data can only be encrypted by manually copying it to a new encrypted disk. The encryption status of an existing disk cannot be changed from unencrypted to encrypted directly.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

5 Relational Database TencentDB for MySQL

This section covers security recommendations that you should follow to secure TencentDB for MySQL（relational database）.

5.1 Ensure TencentDB for MySQL instance requires all incoming connections to use SSL (Automated)

Profile Applicability:

- Level 1

Description:

SSL (Secure Sockets Layer) authentication secures connections between the client and the TencentDB for MySQL instances through authenticating both the user and the server.When SSL encryption is enabled, a CA certificate is obtained and uploaded to the server.When the client connects to the database, the SSL protocol establishes a secure SSL channel that encrypts data in transit, preventing interception, tampering, or eavesdropping, ensuring the secure exchange of information.

Rationale:

When SSL, all information transferred over the network will be in plaintext, making it vulnerable to eavesdropping, tampering, and impersonation by malicious users. Enabling SSL addresses these risks and provides the following protections:

- Data in transit is encrypted preventing eavesdropping.
- Communication integrity is verified, allowing immediate detection of tampering detection.
- Identity certificates authenticate the server and client, ensuring secure and trusted connections.

Audit:

Using the management console:

1. Log in to the TencentDB for MySQL console.
2. In the `Instance List`, click an `Instance ID` or Manage in the `Operation` column to enter the instance management page.
3. On the Instance Management page, select the `Data Security` > `SSL` tab.
4. Check whether the button after Status is `enabled`, and if so, SSL is enabled for the instance.

Remediation:

Using the management console:

1. Log in to the TencentDB for MySQL console.
2. In the `Instance List`, click an `Instance ID` or Manage in the `Operation` column to enter the instance management page.
3. On the Instance Management page, select the `Data Security` > `SSL` tab.
4. The default status of this function is not enabled, turn on the button after "Status", and then click `OK` to enable SSL.
5. Click Download to download the SSL CA certificate.The certificate has a validity period of 20 years.

   The downloaded file is a compressed package (TencentDB-CA-Chain.zip), which contains the following three files:

- .p7b file: It is used to import the CA certificate into Windows.
- jks file: A storage file for truststore and keystore in Java with a unified password of tencentdb, used for importing the CA certificate chain in Java programs.
- .pem file: It is used to import the CA certificate into other systems or applications.

Default Value:

By default, SSL is not enabled.

References:

1. https://www.tencentcloud.com/document/product/236/48452

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●
v7	16.5 Encrypt Transmittal of Username and Authentication Credentials Ensure that all account usernames and authentication credentials are transmitted across networks using encrypted channels.		●	●

5.2 Ensure TencentDB for MySQL instance does not allow public access (Automated)

Profile Applicability:

- Level 1

Description:

TencentDB instances use Security Groups to control inbound and outbound network access. It is recommended that TencentDB for MySQL instances are not configured to allow public access.

Rationale:

Allowing public access exposes database instances to the internet, increasing the risk of unauthorized access, data leakage, or malicious activity. Restricting access ensures that only trusted networks or clients can connect to the database, reducing the attack surface and protecting sensitive data.

Audit:

Perform the following to check:

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. In the `Instance List`, click an `Instance ID` or Manage in the `Operation` column to enter the instance management page.
3. On the Instance Management page, choose the `Security Group` page.
4. On the Security Group page, check whether a security group is configured for the current instance, and that the inbound rules of the security group DO NOT open `all ports`.

Remediation:

Create a security group, configure inbound rule and bind it to the TencentDB for MySQL instance to restrict public access to the database:

Using the Security Group Console:

1. Log in to the Security Group Console.
2. select a `region`, and click `Create`.
3. In the pop-up dialog window, complete the configuration as needed (do not select "Open all ports" for the template), and click `OK`.
4. Find the newly created security group in the security group list and click `Modify Rule` in its Operation column.
5. Under `Security group rules` > `Inbound rules`, click `Add rule`, configure the `source`, `protocol:port`, and `policy` as needed, and click `OK` to complete the creation of the security group.

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. In the `Instance List`, click an `Instance ID` or Manage in the `Operation` column to enter the instance management page.
3. On the Instance Management page, choose the `Security Group` page.
4. On the Security Groups page, click `Configure Security Group`, and then check the security group created above in the pop-up window. If the current instance has selected security groups that open all ports, you need to uncheck them accordingly, and finally click `OK`.

Default Value:

By default, the whitelist is configured as ’127.0.0.1’, disallowing any connections from external servers.

References:

1. https://www.alibabacloud.com/help/doc-detail/26198.htm

Additional Information:

For RDS instances using IPv6, ensure the whitelist is appropriately configured to avoid granting access to all IPv6 addresses.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.3 Ensure the 'Audit Function' for TencentDB for MySQL instance is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2

Description:

Database Audit, developed by Tencent Cloud, is a comprehensive, real-time auditing solution for database security. It records database activities, provides fine-grained audit compliance management for database operations and can trigger alerts for risky or suspicious behavior.

Rationale:

Enabling database auditing helps log all database access and SQL statement executions, supporting risk management and enhancing data security. It allows configuration of alert strategies based on high, medium, or low risk levels. When a rule is triggered, the audit system can notify bound users. Users can view alert history, manage alert strategies (e.g., enable/disable alerts), and configure alert suppression in the Tencent Cloud Observability Platform (TCOP), enabling timely detection and accurate identification of security-relevant events.

Audit:

Do the following to check that database audit is turned on:

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. On the left sidebar, click `Database Audit`.
3. Under the list of audit instance, find the target instance and check whether its audit log storage status is `Enabled`.

Remediation:

Do the following to enable database audit:

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. On the left sidebar, click `Database Audit`.
3. Under the list of audit instance, find the target instance and click `Enable Database Audit` in its Operation column.
4. On the page that jumps to the page, click `OK` after completing the settings as needed.

Default Value:

By default, Audit Logs are not enabled.

References:

1. https://cloud.tencent.com/document/product/236/81405

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.14 Log Sensitive Data Access Log sensitive data access, including modification and disposal.			●
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	14.9 Enforce Detail Logging for Access or Changes to Sensitive Data Enforce detailed audit logging for access to sensitive data or changes to sensitive data (utilizing tools such as File Integrity Monitoring or Security Information and Event Monitoring).			●

5.4 Ensure 'Auditing Retention' for TencentDB for MySQL instance is greater than 6 months (Automated)

Profile Applicability:

- Level 1

Description:

TencentDB for MySQL provides auditing capabilities to record database access and SQL statement execution, helping enterprises manage risks and enhance data security. It is recommended to configure audit log retention to be greater than 6 months to meet operational and compliance requirements.

Rationale:

Configuring audit logs to be retained for more than 6 months ensures sufficient historical data for security monitoring, incident investigation, and compliance requirements.

Audit:

Perform the following to check whether the Log Retention Period of is greater than 180 days:

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. On the left sidebar, click `Database Audit`.
3. Under the list of audit instance, find the target instance and check whether its total storage period is greater than 180 days.

Remediation:

Perform the following to modify the database audit retention duration of an instance to be greater than 180 days:

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. On the left sidebar, click `Database Audit`.
3. Under the audit instance list, locate the target instance and click `More` > `Modify Audit Service` in its operation column.
4. In the pop-up window, set the `log retention period` to 180 days or longer.

Default Value:

By default, the retention period is 30 days.

References:

1. https://cloud.tencent.com/document/product/236/81406

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.14 Log Sensitive Data Access Log sensitive data access, including modification and disposal.			●
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●
v7	14.9 Enforce Detail Logging for Access or Changes to Sensitive Data Enforce detailed audit logging for access to sensitive data or changes to sensitive data (utilizing tools such as File Integrity Monitoring or Security Information and Event Monitoring).			●

5.5 Ensure TencentDB for MySQL instance has TDE (Transparent Data Encryption) set to 'Enabled' (Manual)

Profile Applicability:

- Level 1

Description:

TencentDB for MySQL supports Transparent Data Encryption (TDE), which encrypts and decrypts data files automatically, without user intervention. Data is encrypted before being written to disk and decrypted when read into memory. It is recommended to enable TDE to ensure data at rest is protected and compliance requirements are met.

Rationale:

Enabling TDE ensures that sensitive data stored in TencentDB for MySQL is encrypted, reducing the risk of unauthorized access in case of storage compromise. Users may also use their own certificates to manage encryption keys, providing additional control over data security.

Audit:

Perform the following to determine if TDE is enabled:

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. In the instance list, click the `Instance ID` or the `Manage option` in the operation column to access the instance management page.
3. Select `Data Security` > `Data Encryption`, then verify whether the encryption status toggle button is `Enabled` .

Remediation:

Perform the following to enable TDE:

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. In the instance list, click the `Instance ID` or the `Manage option` in the operation column to access the instance management page.
3. Select `Data Security` > `Data Encryption` and turn on the button after the `Encryption Status`.
4. In the pop-up window, select the encryption key and click `Encrypt`.

Default Value:

By default, TDE (Transparent Data Encryption) is not enabled.

References:

1. https://cloud.tencent.com/document/product/236/41101

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

5.6 Ensure the TDE (Transparent Data Encryption) protector of theTencentDB for MySQL instance uses BYOK (Bring Your Own Key) encryption (Automated)

Profile Applicability:

- Level 2

Description:

TencentDB for MySQL's Transparent Data Encryption (TDE) relies on encryption keys managed by Tencent Cloud's Key Management Service (KMS). It is recommended to enable BYOK (Bring Your Own Key), allowing users to provide or generate their own encryption keys for TDE, giving them full control over key management and encryption.

Rationale:

Using BYOK ensures that sensitive data is encrypted with keys managed by the user, providing enhanced control over data security and compliance. This reduces reliance on platform-managed keys and allows organizations to meet internal or regulatory requirements for key ownership.

Audit:

Perform the following steps to check whether a TDE-enabled instance is configured to "Use existing custom key":

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. In the instance list, click the `Instance ID` or the `Manage option` in the operation column to access the instance management page.
3. Navigate to `Data Security` > `Data Encryption`, then check the `key list` for any custom key. If a custom key exists, it indicates the instance is configured to `"Use existing custom key"`; if no custom key is found, the instance uses `"Use key auto-generated by Tencent Cloud"`.

Remediation:

Perform the following steps to enable TDE encryption for the instance using existing custom key:

Using the TencentDB for MySQL Console:

1. Log in to the TencentDB for MySQL console.
2. In the instance list, click the `Instance ID` or the `Manage option` in the operation column to access the instance management page.
3. Select `Data Security` > `Data Encryption` and turn on the button after the `Encryption Status`.
4. In the pop-up window, select `"Use existing custom key"` as the encryption method, then choose the `region` and corresponding `key`. Alternatively, click `"Go to Create"` to generate a new custom key before selection. Finally, click `"Encrypt"` to complete the process.

Default Value:

By default, TDE (Transparent Data Encryption) is not enabled.

References:

1. https://cloud.tencent.com/document/product/236/41101

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

6 Kubernetes Engine

This section covers recommendations addressing Kubernetes Engine on Tencent Cloud.

6.1 Ensure Cluster Audit is set to 'Enabled' on Kubernetes Engine Clusters (Automated)

Profile Applicability:

- Level 1

Description:

Cluster audit is a feature based on Kubernetes Audit that records all access events to the kube-apiserver. These logs are stored in JSON format and can be searched or used to generate configurable policies. These logs capture activities performed by users, administrators, and system components that impact the cluster, including metadata (such as the request initiator, source, and accessed URI) and, depending on audit level, request and response objects.

Rationale:

Enabling Cluster Audit provides visibility into Kubernetes cluster's operations from an auditing perspective, such as:

- Activities that occur in the cluster
- Activity occurrence times and objects
- Activity triggering times, triggering positions, and observation points
- Activity results and subsequent processing.

This ensures accountability, supports compliance requirements, and provides reliable evidence for incident investigation and forensic analysis.

Audit:

Using the management console:

1. Log in to the TKE console and select the target cluster.
2. Choose `Cluster OPS > Feature Management` in the left sidebar to go to the Feature Management page.
3. At the top of the "Feature Management" page, select the `region`. Check the cluster audit status.

Remediation:

Using the management console:

1. Log in to the TKE console and select the target cluster.

   2.Choose `Cluster OPS > Feature Management` in the left sidebar to go to the Feature Management page.

2. At the top of the "Feature Management" page, select the `region`. Click `Set for the cluster` that you want to enable cluster audit.
3. In the "Configure a Feature" window that appears, click `Edit` for the "Cluster Audit" feature.
4. Select `Enable Cluster Audit` and select `the logset` and `log topic` for storing audit logs. We recommend that you select `Automatically Create a Log Topic`.
5. Click `OK` to enable the cluster audit feature.

Default Value:

By default, cluster audit is disabled when you create a new cluster using console.

References:

1. https://www.tencentcloud.com/document/product/457/38338

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.2 Ensure Cloud Monitoring is set to Enabled on Kubernetes Engine Clusters (Automated)

Profile Applicability:

- Level 1

Description:

A healthy monitoring environment helps ensure the reliability, availability, and performance of Tencent Cloud's Tencent Kubernetes Engine (TKE). Cloud Monitoring collects metrics across multiple dimensions and resources, making it easier to understand resource usage and identify problems.

Rationale:

Tencent Cloud TKE supports monitoring and visualization at 5 levels: cluster, node, workload, pod, and container.

The collection of monitoring data helps establish baseline performance standards and detect anomalies. By testing performance at different times and under different load conditions, user can better understand the normal performance of a container cluster or service, enabling faster identification of abnormal states and timely response. Some of the metrics that can be monitored are service's CPU utilization, memory usage, or disk I/O.

Audit:

Using the management console:

1. Log in to the TKE console and select the target cluster.
2. Click `Monitoring` in the row of the cluster for which you want to view the monitoring data.

Remediation:

Cloud Monitoring is always enabled when you create a new cluster using console.

Default Value:

Cloud Monitoring is always enabled when you create a new cluster using console.

References:

1. https://www.tencentcloud.com/document/product/457/30688
2. https://www.tencentcloud.com/document/product/457/30689

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.3 Ensure role-based access control (RBAC) authorization is Enabled on Kubernetes Engine Clusters (Automated)

Profile Applicability:

- Level 1

Description:

TKE supports the Kubernetes RBAC authorization, enabling fine-grained access control for sub-accounts. With RBAC, users can access resources through the TKE console and kubectl.

Rationale:

Role-Based Access Control (RBAC) maps users and permissions to roles, granting appropriate permissions to users and groups through roles.

In Kubernetes, RBAC is implemented through the rbac.authorization.k8s.io API group, allowing cluster administrators to dynamically configure and enforce authorization policies using Kubernetes APIs.

Audit:

Using the management console:

1. Log in to the TKE console.
2. On the Cluster Management page, click the `ID of the target cluster`.
3. On the cluster details page, select `Authorization Management` -> `ClusterRole` on the left sidebar.
4. On the ClusterRole page, click `RBAC Policy Generator` to configure the RBAC roles.

Remediation:

Using the management console:

1. Log in to the TKE console.
2. On the Cluster Management page, click the `ID of the target cluster`.
3. Select an item under the cluster's Authorization Management page, and click `RBAC Policy Generator` on the corresponding management page.
4. When you select a `sub-account` on the Administration Permissions page, select the sub-account whose permissions you want to repossess and then click `Next`.
5. When you set the `cluster RBAC`, you can also set permissions. For example, select Read-only Users as the Permission Setting for the default namespace.
6. Click `Done` to complete the repossession.

Default Value:

By default, RBAC authorization is enabled.

References:

1. https://www.tencentcloud.com/document/product/457/37366
2. https://www.tencentcloud.com/document/product/457/37367

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	14 Controlled Access Based on the Need to Know Controlled Access Based on the Need to Know			

6.4 Ensure Cluster Health Check triggered at least once per week for Kubernetes Clusters (Automated)

Profile Applicability:

- Level 1

Description:

Tencent Kubernetes Engine (TKE) provides a cluster health check feature to evaluate the status and health of cluster resources. The resulting report displays the detailed information on the components, nodes, workloads, and other items. If an exception is detected, this feature will provide insights on the issue, automatically analyze its severity, cause, and impact, and propose rectification suggestions.

Rationale:

The main check Items of cluster health check:

- Check whether the component is running.
- Check whether the node status is Ready and free of issues, such as insufficient memory and insufficient disk space.
- Check whether the number of available pods meets the workload expectations.
- Check whether the current cluster is a single-node deployment.
- Check whether containers in workload are configured with resource limits.
- Check whether affinity or anti-affinity is configured for workload.
- Check whether PDB is configured for workload to maintain availability during eviction.
- Check whether health checks are configured for workloads.
- Check whether remaining pod IP addresses are sufficient for HPA scale-out.

Audit:

Using the management console:

1. Log in to the TKE console and select the target cluster.
2. On the Cluster Management page, choose `Cluster OPS` > `Health Check` in the left sidebar.
3. On the Health Check page check the Auto Check status.

Remediation:

Using the management console:

1. Log in to the TKE console console and select the target cluster.
2. On the Cluster Management page, choose `Cluster OPS` > `Health Check` in the left sidebar.
3. On the Health Check page that appears, select the health check mode for the cluster. In the Health Check page, click `Auto Check`.
4. In the Auto-Checking Settings window that appears, you can `enable/disable` auto-check, and set the check period and time based on your needs.

Default Value:

By default, the auto check is disabled.

References:

1. https://www.tencentcloud.com/document/product/457/38428

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

6.5 Ensure Kubernetes web UI / Dashboard is not enabled (Automated)

Profile Applicability:

- Level 1

Description:

Kubernetes Dashboard is a web-based Kubernetes user interface that can be used to deploy containerized applications to a Kubernetes cluster, troubleshoot containerized application, and manage cluster resources. It provides an overview of applications running on your cluster, and allows users to create or modify Kubernetes resources (e.g. Deployments, Jobs, DaemonSets, etc). For example, you can scale a Deployment, initiate a rolling update, restart a pod or deploy new applications using the deploy wizard.

Rationale:

The Kubernetes Web UI (Dashboard) runs with a highly privileged Kubernetes Service Account, which increases the risk of privilege escalation if the dashboard is compromised. It is recommended to disable the Dashboard when using TKE and manage resources securely through the TKE Console.

Audit:

Using the management console:

1. Log in to the TKE console and select the target cluster.
2. Select the target cluster and select the kube-system namespace in the `Namespace` pop-menu
3. Input `dashboard` in the deploy filter bar, and make sure there is no result exist after the filter.

Remediation:

Using the management console:

1. Log in to the TKE console and select the target cluster.
2. Select the target cluster and select the kube-system namespace in the `Namespace` pop-menu.
3. Input `dashboard` in the deploy filter bar, make sure there is no result exist after the filter, delete the dashboard deployment by selecting the `Delete` in `More` pop-menu.

Default Value:

By default, the kube-dashboard is not installed/enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

6.6 Ensure Basic Authentication is not 'Enabled' on Kubernetes Engine Clusters (Automated)

Profile Applicability:

- Level 1

Description:

Basic authentication allows users access the Kubernetes cluster with a username and password, which are stored in plain text without any encryption. This creates security risks, such as intercepted credentials and brute-force attacks. Disabling Basic authentication reduces these risks.

Rationale:

Basic Authentication creates security risks, such as intercepted credentials and brute-force attacks. Disabling Basic authentication reduces these risks.

It is recommended to disable Basic Authentication and use client certificate to securely access Kubernetes cluster. A client certificate is a base 64-encoded public certificate used by clients to authenticate to the cluster endpoint, providing stronger security than Basic Authentication.

Audit:

1. ssh into any master node in cluster
2. Make sure the basic-auth-file not exist in apiserver manifest with below command:

```
cat /etc/kubernetes/manifests/kube-apiserver.yaml | grep basic-auth-file
```

Remediation:

1. ssh into any master node in cluster.
2. Make sure the basic-auth-file not exist in apiserver manifest with below command:

```
cat /etc/kubernetes/manifests/kube-apiserver.yaml | grep basic-auth-file
```

3. If you found basic-auth-file existing in apiserver manitfest, please override the manifest file with new manifest content to not include the basic-auth-file and then restart the apiserver, you need repeat the action on all of the master nodes

Default Value:

By default, Basic Authentication is not enabled when you create a new cluster.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 Centralize Account Management Centralize account management through a directory or identity service.		●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

6.7 Ensure Network policy is 'Enabled' on Kubernetes Engine Clusters (Manual)

Profile Applicability:

- Level 1

Description:

Network Policy is a Kubernetes resource used to define pod-level network isolation rules. It controls whether a group of pods can communicate with other groups or external network entities, providing fine-grained control over traffic flow within the cluster.

Rationale:

Enabling Network Policy allows user to restrict network traffic at the IP address or port level (Layer 3/Layer 4 of the OSI model), securing communication between workloads and prevents unauthorized or unintended network access..

Audit:

Using the management console:

1. Log in to the TKE console .
2. On the `Cluster Management` page, click the `ID` of the target cluster to go to the cluster details page.
3. In the left sidebar, click `Add-on Management` to go to the Add-on List page.
4. On the Add-on List page, check `NetworkPolicy` is installed or not.

Remediation:

Using the management console:

1. Log in to the TKE console .
2. On the `Cluster Management` page, click the `ID` of the target cluster to go to the cluster details page.
3. In the left sidebar, click `Add-on Management` to go to the Add-on List page.
4. On the Add-on List page, click `Create and select NetworkPolicy` in the pop-up `Create Add-on` window. For details of NetworkPolicy configuration.
5. Click `Done`.

Default Value:

By default, Network Policy is disabled when you create a new cluster.

References:

1. https://www.tencentcloud.com/document/product/457/39120

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.12 Segment Data Processing and Storage Based on Sensitivity Segment data processing and storage based on the sensitivity of the data. Do not process sensitive data on enterprise assets intended for lower sensitivity data.		●	●
v7	14.1 Segment the Network Based on Sensitivity Segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).		●	●

6.8 Ensure VPC-CNI Mode support for Kubernetes Cluster (Automated)

Profile Applicability:

- Level 1

Description:

VPC-CNI is a container network capability provided by TKE based on CNIs and VPC ENIs. It is designed for scenarios with high performance and low latency requirements. In this mode, containers and nodes share the same network plane, and container IP addresses are ENI IP addresses allocated by the IPAMD component.

Rationale:

The VPC-CNI mode supports the shared and exclusive ENI modes for different scenarios, which can be selected based on workload requirements.

- Shared ENI mode: Pods share an ENI, with the IPAMD component allocating multiple ENI IP addresses across Pods. Pod IP addresses can be fixed. For more information, see Static IP Address Features.
- Exclusive ENI mode: Each Pod uses an exclusive ENI for higher performance. The number of ENIs available per node varies depending on model, with fewer numbers for single-node cluster. .

Audit:

Using the management console:

1. Log in to the TKE console .
2. On the `Cluster Management` page, click the `ID` of the target cluster to go to the cluster details page.
3. In the left sidebar, click `Add-on Management` to go to the `Add-on List` page.
4. On the `Add-on List` page, check `NetworkPolicy` is installed or not.

Remediation:

Using the management console:

1. Log in to the TKE console and select the target cluster.
2. On the `Cluster Management` page, click the `ID` of the target cluster to go to the cluster details page.
3. In the left sidebar, click `Add-on Management` to go to the `Add-on List` page.
4. On the `Add-on List` page, click `Create and select NetworkPolicy` in the pop-up `Create Add-on` window. For details of NetworkPolicy configuration.
5. Click `Done`.

Default Value:

By default, Network Policy is disabled when you create a new cluster.

References:

1. https://www.tencentcloud.com/document/product/457/38970

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.12 Segment Data Processing and Storage Based on Sensitivity Segment data processing and storage based on the sensitivity of the data. Do not process sensitive data on enterprise assets intended for lower sensitivity data.		●	●
v7	14.1 Segment the Network Based on Sensitivity Segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).		●	●

6.9 Ensure Kubernetes Cluster Internet Access is not 'Enabled' (Automated)

Profile Applicability:

- Level 1

Description:

TKE supports accessing Kubernetes cluster through the public internet or private network.

Rationale:

Disabling internet access protects clusters from external attacks. If access is required from outside the cluster, such as through kubectl, it is recommended to enable private network access, ensuring access is only allowed within the same VPC network.

Audit:

Using the management console:

1. Log in to the TKE console.
2. On the `Cluster Management` page, click the `ID` of the target cluster to go to the cluster details page.
3. On the cluster basic information page, check whether internet access is disabled.

Remediation:

Using the management console:

1. Log in to the TKE console and select the target cluster.
2. On the `Cluster Management` page, click the `ID` of the target cluster to go to the cluster details page.
3. On the cluster basic information page, set the `internet access` feature to disabled.

Default Value:

By default, internet access is not enabled when creating a new cluster.

References:

1. https://www.tencentcloud.com/document/product/457/30639

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.12 Segment Data Processing and Storage Based on Sensitivity Segment data processing and storage based on the sensitivity of the data. Do not process sensitive data on enterprise assets intended for lower sensitivity data.		●	●
v7	14.1 Segment the Network Based on Sensitivity Segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).		●	●

7 Cloud Security Center

This section covers security recommendations to follow when setting various security policies on an Tencent Cloud subscription. A security policy defines the set of controls, which are recommended for resources within the specified Tencent Cloud subscription. Please note that the majority of the recommendations mentioned in this section only produce an alert if a security violation is found. They do not actually enforce security settings by themselves. Alerts should be acted upon and remedied wherever possible.

7.1 Ensure Cloud Security Center is Premium, Enterprise or Ultimate Edition (Manual)

Profile Applicability:

- Level 2

Description:

Tencent Cloud Security Center Premium, Enterprise or Ultimate Edition strengthens security protection and management in cloud-native environments, providing asset management, security health checks, port/vulnerability/weak password/cloud resource configuration/website content scanning, attack and alert handling, security reports, and other features. It is recommended to use one of these editions to leverage comprehensive security capabilities.

Rationale:

The free version only supports basic features, including asset management, port scanning, and alert integration. Premium, Enterprise, and Ultimate Editions offers advanced security features to improve visibility, detection and response across cloud assets.

Impact:

Enabling Premium, Enterprise or Ultimate Editions may incur additional costs.

Audit:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Security Overview`
3. Ensure the current edition: `Free/Premium/Enterprise/Ultimate`

Remediation:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Security Overview`
3. Click `Upgrade now`.
4. Select Premium Edition/Enterprise `Free/Edition/Ultimate Edition`.
5. Finish your order and payment.

Default Value:

By default, it's Free Edition.

References:

1. https://www.tencentcloud.com/document/product/1008

Additional Information:

The free edition cannot detect advanced threats and does not support their mitigation.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.6 Centrally Manage Anti-Malware Software Centrally manage anti-malware software.		●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

7.2 Ensure cloud API exception monitoring is enabled (Manual)

Profile Applicability:

- Level 2

Description:

Enable real-time monitoring of Cloud API access keys (AKs) to track usage, review permission configurations, and monitor call paths. This helps identify potential key leakage, abnormal API calls, and misconfigured permissions. It is recommended to enable cloud API exception monitoring to enhance security oversight.

Rationale:

API key leaks are a common vector for unauthorized access and theft of cloud resources. Continuous monitoring helps detect anomalies promptly and mitigate risks associated with compromised keys.

Impact:

Enabling this functionality may incur additional costs due to the use of Tencent Cloud Security Center and the installation of monitoring agents.

Audit:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Cloud API Anomaly Monitoring` > `Policy Management`.
3. Ensure that the alert switch for system policies is `turned on`.

Remediation:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Cloud API Anomaly Monitoring` > `Policy Management`.
3. `Turn on` the alert switch for system policies.

Default Value:

Not enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

7.3 Ensure member accounts are linked to a group account (Manual)

Profile Applicability:

- Level 2

Description:

Ensure member accounts are linked to a group account. This enables administrators to switch between the group account and member accounts seamlessly, facilitating centralized management and streamlined security operations.

Rationale:

Linking member accounts to a group account enhances visibility and control over security configurations, allowing for efficient monitoring and management of security policies across all associated accounts.

Impact:

Enabling features such as Automatic Quarantine in Cloud Security Center may incur additional costs.

Audit:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Multi-cloud Multi-account Management`.
3. Ensure that the group account is linked to the member accounts of all departments.

Remediation:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Multi-cloud Multi-account Management` > `Connect Multi-cloud Accounts`
3. Click `Tencent Cloud Account`, Go to `Group Account Configuration` and add member accounts.

Default Value:

Not enabled.

References:

1. https://www.tencentcloud.com/document/product/1008/56709

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

7.4 Ensure periodic security check tasks are configured (Manual)

Profile Applicability:

- Level 1

Description:

Configure regular security check tasks for cloud assets, covering open ports, cloud resource configurations, service exposures, vulnerabilities, weak passwords, and content risks. Scheduled checks help maintain continuous security oversight and ensure timely detection of potential issues.

Rationale:

Regular security checks ensure that threats—including exposed ports, sensitive information or services, potential vulnerabilities, weak passwords, and misconfigured cloud resources—are promptly detected and remediated, reducing the risk of compromise.

Audit:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Health check tasks`.
3. Ensure that a security check task (periodic task) has been created.

Remediation:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Health check tasks`.
3. Click `Create Task`.
4. Edit the `task name`, `mode`, set the `Plan` ,`Check items` and `Include assets`.
5. Click `OK`.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1008/56705

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●

7.5 Ensure notification is enabled for high-risk security activities (Manual)

Profile Applicability:

- Level 1

Description:

For high-risk security events, ensure that multiple notification channels such as internal messages, text messages, and emails are enabled and configured to alert relevant security personnel promptly.

Rationale:

Timely alerts allow security operations personnel to respond quickly to security incidents, reducing potential impact and mitigating damage.

Audit:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Notification Settings`.
3. Ensure that the notification switch is `turned on` and the notification method is set.

Remediation:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Notification Settings`.
3. Turn on the `Asset Center`, `Alert Center`, `Cloud API Anomaly Monitoring`, and `DNS Threat Monitoring` switches.
4. Click `Subscription Management` to configure notification methods such as internal messages, emails, and text messages.

Default Value:

Only some alert types have notifications enabled by default.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.1 Centralize Security Event Alerting Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.		●	●
v7	6.6 Deploy SIEM or Log Analytic tool Deploy Security Information and Event Management (SIEM) or log analytic tool for log correlation and analysis.		●	●

7.6 Ensure log storage analysis is enabled (Manual)

Profile Applicability:

- Level 1

Description:

Centralize logs from multiple Tencent Cloud products through Cloud Security Center to enable streamlined security log operations and maintenance. It is recommended to configure log retention to be greater than 6 months to meet operational and compliance requirements.

Rationale:

Centralized log storage and analysis help meet security audit and compliance requirements, and provide reliable evidence for event investigation and tracing.

Impact:

Enabling log storage and analysis may incur additional charges for the service.

Audit:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Log Analysis`.
3. Click `Configure log sources`.
4. Ensure that the log source is connected and that the storage switch for each log type is `turned on`.

Remediation:

Using the management console:

1. Log in to the Cloud Security Center console.
2. Select `Log Analysis`.
3. Click `Configure log sources` > `Access Log Source`.
4. Select the `log source` and `storage duration`, and `enable` the storage switch for each log type.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1008/56708

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

8 Cloud Workload Protection Platform

This section covers security recommendations to follow when configuring the Cloud Workload Protection Platform (CWPP), which leverages machine learning to provide a wide variety of security protection services, including asset management, trojan detection and prevention, intrusion detection, vulnerability alerting, and security baseline.

8.1 Ensure CVM server has installed Cloud Workload Protection Platform(CWPP) Agent (Automated)

Profile Applicability:

- Level 1

Description:

The CWPP agent collects host risk information and synchronizes it with the management console. It also execute detection and processing tasks issued by the management console. Ensure that agent is installed on all deployed CVM servers.

Rationale:

Without the CWPP agent installed, security detection and protection cannot be performed on the server.

Impact:

The basic edition is free but may not provide full host security protection capabilities.

Audit:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Server List`.
3. Click `Agent not installed` to filter out hosts that do not have the agent installed.

Remediation:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Server List`.
3. Click `Agent not installed` to filter out hosts that do not have the agent installed.
4. In the `Operation` column of the host that does not have the client installed, click `Install CWPP Agent` to open the client installation guide. Select the appropriate installation method based on the server situation.

Default Value:

By default, CWPP agent is installed.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

8.2 Ensure CVM server has installed the Cloud Workload Protection Platform(CWPP) Professional or Ultimate edition agent (Automated)

Profile Applicability:

- Level 2

Description:

The CWPP Professional Edition or Ultimate Edition provides advanced security features such as asset management, malware detection and removal, hacker intrusion prevention, vulnerability risk alerts, and security baseline compliance.

Rationale:

The basic edition only supports abnormal login and password cracking monitoring. Advanced protection features require the Professional or Ultimate Edition.

Impact:

Professional or Ultimate editions require additional purchase.

Audit:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Server List`.
3. Click "CWP Basic Servers" to filter out basic servers.

Remediation:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `License management`.
3. Click `Purchase CWPP License` to go to the cwpp purchase page.
4. Select the `Professional` or `Ultimate` edition, enter the number of protection licenses, and bind the base edition host that needs to be upgraded.
5. Complete your order and payment.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/296/48331

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

8.3 Ensure that the Cloud Workload Protection Platform(CWPP) application protection switch is 'Turn on' (Manual)

Profile Applicability:

- Level 2

Description:

Enable the application protection switch in CWPP to activate vulnerability defense and Java Webshell defense. This setup helps defend against vulnerability exploitation attacks and Java Webshell attacks by generating virtual patches and monitoring Java Web Service processes for unauthorized code injections. These features are only available in Professional and Ultimate Editions of CWPP.

Rationale:

Activating application protection allows CWPP to automatically generate virtual patches for detected vulnerabilities and monitor Java Web Service processes for unauthorized code injections, enhancing the security posture of your assets.

Impact:

Enabling application protection may incur additional charges, depending on the CWPP edition and licensing.

Audit:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Cyber Defense` > `Application protection`.
3. Click `Protection Switch Configuration`.
4. Ensure that the protection switches for host assets and container assets are turned on.

Remediation:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Cyber Defense` > `Application protection`.
3. Click `Protection Switch Configuration`.
4. `Turn on` the protection switch for host assets and container assets.

Default Value:

Not configured.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

8.4 Ensure CWPP agent 'self-protection', 'scheduled scanning', and 'automatic defense' are 'Enabled' (Manual)

Profile Applicability:

- Level 1

Description:

Configure the agent self-protection, scheduled scanning, and automatic defense security switches in CWPP.

Rationale:

Without agent self-protection enabled, attackers can uninstall the agent and evade detection. If scheduled scans are not configured, new risks may go undetected. The absence of automatic defense mechanisms means that attacks will only trigger alerts without being blocked.

Impact:

If these switches are not enabled, the integrity of the CWPP protection service cannot be guaranteed.

Audit:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Security Overview`.
3. Ensure that `Client & Authorization Settings`, `Scheduled Scan Settings`, and `Automatic Defense Settings` under the `Security Switch` module are all enabled.

Remediation:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Security Overview`.
3. Configure and enable the `Client & Authorization Settings`, `Scheduled Scan Settings` and `Automatic Defense Settings` under the `Security Switch` module.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/296/35234

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

8.5 Ensure notification is enabled for all high-risk security activities (Manual)

Profile Applicability:

- Level 1

Description:

For serious or high-risk security risks, ensure that multiple notification channels such as internal messages, text messages, and emails are properly configured and enabled.

Rationale:

Timely alerts allow security operations personnel to respond quickly to security incidents, reducing potential impact and mitigating damage.

Impact:

Failure to notify in a timely manner will result in untimely risk handling, which may increase the damage caused by the attack.

Audit:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Notification Settings`.
3. Ensure that the `alarm statues` for each `alarm type` are turned on and that the `alarm time`, `alarm host range` and `alarm items` are configured.
4. Click `Go to Settings` to go to `Message Center` > `Subscription Management` and ensure that the CWPP message reception channel has been set up.

Remediation:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Notification Settings`.
3. Ensure that the `alarm statues` for each `alarm type` are turned on and that the `alarm time`, `alarm host range` and `alarm items` are configured.
4. Click `Go to Settings` to go to `Message Center` > `Subscription Management` and ensure that the CWPP message reception channel has been set up.

Default Value:

Only some alert types have notifications enabled by default.

References:

1. https://www.tencentcloud.com/document/product/296/69085

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.1 Centralize Security Event Alerting Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.		●	●
v7	6.6 Deploy SIEM or Log Analytic tool Deploy Security Information and Event Management (SIEM) or log analytic tool for log correlation and analysis.		●	●

8.6 Ensure log storage analysis is enabled (Manual)

Profile Applicability:

- Level 1

Description:

Enable CWPP log collection and storage, including host asset logs, client-reported logs, and alert logs, with a retention period of at least six months.

Rationale:

Centralized log storage and analysis help meet security audit and compliance requirements, and provide reliable evidence for event investigation and tracing.

Impact:

Enabling log storage and analysis may incur additional charges for the service.

Audit:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Log Analysis`.
3. Click `Log Configuration`.
4. Ensure that you have purchased log analysis storage space and that the purchase period is no less than six months. Also, ensure that you have configured the storage content and the storage period for automatic cleanup.

Remediation:

Using the Management Console:

1. Log in to the Cloud Workload Protection Platform.
2. Select `Log Analysis`.
3. Click `Buy Now` to proceed to the Host Security purchase page.
4. Select the log analysis storage capacity with a minimum duration of 6 months, then complete the order and payment.
5. Return to `Log Analysis`.
6. Click `Log Configuration`.
7. Configure storage content and the duration for triggering automatic cleanup.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/296/60392

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

9 Tencent Container Security Service

This section covers security recommendations to follow when configuring the Tencent Container Security Service to safeguard containers through their entire lifecycle from image generation and storage to runtime.

9.1 Ensure Container Security protection is enabled for clusters and hosts (Automated)

Profile Applicability:

- Level 1

Description:

The Tencent Container Security Service (TCSS) Professional Edition provides comprehensive security services to safeguard containerized environments throughout their entire lifecycle – from image creation and storage to runtime.

Rationale:

The Professional Edition provides core protection capabilities such as runtime intrusion interception, container escape defense, and malicious file isolation, ensuring robust security for containerized applications.

Impact:

Enabling Professional Edition may incur additional charges.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Protection switch`.
3. Ensure that the current version is Container Security Professional Edition and that protection switches are enabled for the cluster and host nodes.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Protection switch`.
3. Click `Buy Now`.
4. Enter the number of protection units, complete the order, and make payment.
5. Return to `Protection Switch` and enable the `protection switch` for the cluster and host nodes.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/zh/document/product/1163/50874

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

9.2 Ensure Image Scan is Enabled (Manual)

Profile Applicability:

- Level 2

Description:

TCSS Image Scan provides comprehensive security detection for container images, enabling users to identify security vulnerabilities, sensitive data risks, and Trojan viruses within image repositories.

Image Scan adopts a monthly quota system, where unused quotas from the previous month will be invalidated. Thus, it is recommended to purchase scan quotas based on actual consumption.

Rationale:

Enabling Image Scan ensures that container images are continuously assessed for security vulnerabilities, sensitive data exposure, and malware. This reduces the risk of deploying compromised images into production, helps meet compliance requirements, and strengthens overall container security posture.

Impact:

Enabling Image Scan may incur additional charges.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Security Overview`.
3. View the remaining scan quota for mirror image scanning.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Security Overview`.
3. Click `Buy Now`.
4. Enter the image scan quota, complete the order, and make payment.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1163/50875

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

9.3 Ensure TCSS application protection switch is 'Turn on' (Manual)

Profile Applicability:

- Level 2

Description:

Enable the application protection switch in TCSS to activate vulnerability defense and Java Webshell defense. This setup helps defend against vulnerability exploitation attacks and Java Webshell attacks by generating virtual patches and monitoring Java Web Service processes for unauthorized code injections.

Rationale:

Activating application protection allows TCSS to automatically generate virtual patches for detected vulnerabilities and monitor Java Web Service processes for unauthorized code injections, enhancing the security posture of your assets.

Impact:

Not enabled may result in the container being compromised.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Advanced Prevension` > `Application protection`.
3. Click on `Protection Switch Configuration`.
4. Ensure that the protection switches for host assets and container assets are enabled.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Advanced Prevension` > `Application protection`.
3. Click on `Protection Switch Configuration`.
4. `Turn on` the protection switch for host assets and container assets.

Default Value:

Not configured.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

9.4 Ensure Container Asset has installed Container Security Agent (Manual)

Profile Applicability:

- Level 1

Description:

Installing Container Security Agent on container assets enable continuous security monitoring and protection.

Rationale:

Installing the Container Security agent is essential to ensure that container assets are continuously monitored and protected. Without the agent, TCSS cannot detect runtime risks, intrusion attempts, misconfigurations, or vulnerabilities in clusters and container instances, leaving your container environment exposed to security threats.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select "Asset Management."
3. Click `Cluster` and filter clusters with protection status set to `Not accessed`.
4. Return to `Asset Management`.
5. Click `Servers` and filter hosts with `Docker version not installed`.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Asset Management`.
3. Click `Install Agent Now` to view the installation instructions. Select the appropriate installation method based on the cluster and host node conditions, and then proceed with the installation.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1163/50877

Additional Information:

- Without installing the Agent, you cannot implement any security detection or protection using container security.
- May incur additional charges.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

9.5 Ensure Scheduled Image Scanning is Configured (Automated)

Profile Applicability:

- Level 1

Description:

Scheduled image scanning automatically scans container images at regular intervals or when new images are added to repositories. It covers the latest image versions and images currently running in containers. When changes are detected in images within the scan scope, the scan scope is automatically updated to include them.

Rationale:

Scheduled image scanning ensures that security vulnerabilities, sensitive information, or malicious code in images are detected before deployment, preventing risky images from entering production environments.

Impact:

Enabling scheduled image scanning may incur additional charges.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Image Risk Control` > `Local images` or `Repository Images`.
3. Click `Scheduled scan settings`.
4. Ensure that the scheduled scan switch is `turned on`, and that the scheduled scan time and scan range have been set.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Image Risk Control` > `Local images` or `Repository Images`.
3. Click `Scheduled scan settings`.
4. `Turn on` the scheduled scan switch, set the scheduled scan time and scan range.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1163/50891
2. https://www.tencentcloud.com/document/product/1163/50892

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

9.6 Ensure Automatic Cluster Check is 'Enabled' (Manual)

Profile Applicability:

- Level 1

Description:

Configure automated security checks for Kubernetes clusters to identify configuration risks. This involves installing the cluster-security-defender DaemonSet on all nodes, which performs nightly scans and automatically checks newly added nodes.

Rationale:

Regularly scheduled cluster checks help detect misconfigurations and vulnerabilities early, reducing the risk of unauthorized access or exploitation. Configuration errors are among the most common attack vectors for container clusters.

Impact:

- Unresolved cluster configuration risks may result in the cluster being taken over in bulk.
- May incur additional charges.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Cluster Security` > `Cluster check`.
3. Ensure that the Auto-Check switch is enabled for the target cluster ID/name.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Cluster Security` > `Cluster check`.
3. Enable the Auto-Check switch for the target cluster `ID/name` .
4. In the pop-up window, click `OK`

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1163/50894

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●

9.7 Ensure Vulnerability Scanning is enabled (Manual)

Profile Applicability:

- Level 1

Description:

Regularly scan container images and running containers for system vulnerabilities and web application vulnerabilities to maintain a secure container environment.

Rationale:

Enabling scheduled vulnerability scanning ensures that new vulnerabilities in containers are detected in a timely manner. Without scheduled scans, unpatched vulnerabilities may remain unnoticed, increasing the attack surface.

Impact:

Enabling Vulnerability Scanning may incur additional charges.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Vulnerability management`.
3. Click `Vulnerability detection` > `Scheduled Scan`.
4. Ensure that the scheduled scan switch for local images and repository images is `turned on`, and that the scan cycle and scope are set.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Vulnerability management`.
3. Click `Vulnerability detection` > `Scheduled Scan`.
4. `Turn on` the scheduled scan switch for local images and repository images, and set the scan cycle and scope.

Default Value:

Not configured.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.5 Perform Automated Vulnerability Scans of Internal Enterprise Assets Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans, using a SCAP-compliant vulnerability scanning tool.		●	●
v8	7.6 Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets Perform automated vulnerability scans of externally-exposed enterprise assets using a SCAP-compliant vulnerability scanning tool. Perform scans on a monthly, or more frequent, basis.		●	●
v7	3.1 Run Automated Vulnerability Scanning Tools Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.		●	●

9.8 Ensure Baseline Cycle Detection is Enabled (Manual)

Profile Applicability:

- Level 1

Description:

Regularly check container compliance settings, such as privileged containers, sensitive directory mounts, and other configuration policies, to ensure containers adhere to security best practices throughout their lifecycle. Baseline cycle detection helps identify misconfigurations early and maintain continuous compliance across clusters.

Rationale:

Containers that do not comply with security baselines are significantly more vulnerable to attacks, including privilege escalation, data leakage, and unauthorized access. Enabling periodic baseline checks ensures that configuration deviations are detected promptly, reducing the risk of security incidents and maintaining a strong security posture.

Impact:

Enabling Baseline Cycle Detection may incur additional charges.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Baseline Management`.
3. Click `Baseline policies` > `Baseline Policy List`.
4. Ensure that the periodic detection switch for the baseline policy is `enabled`, and that the scan cycle, detection items, and detection scope are set.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Baseline Management`.
3. Click `Baseline policies` > `Baseline Policy List`.
4. `Turn on` the cycle detection switch for the baseline strategy. The scan cycle, detection items, and detection range have been set.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1163/50898

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

9.9 Ensure Virus Scanning is Enabled (Automated)

Profile Applicability:

- Level 1

Description:

Regularly scan the file system inside containers to detect and identify known malicious files, including Trojans, backdoors, cryptocurrency miners, ransomware, and other malware. Virus scanning ensures that containers remain free from malicious software that could compromise container integrity, propagate laterally across workloads, or exfiltrate sensitive data.

Rationale:

Containers infected with malicious files can become a foothold for attackers, enabling lateral movement, privilege escalation, and data leakage. Enabling virus scanning ensures timely detection and remediation of malware, reducing the risk of container compromise and protecting both the host and the wider container ecosystem.

Impact:

Enabling Virus Scanning may incur additional charges.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Runtime Security` > `Virus Scanning`.
3. Click `Detection settings` > `Scheduled Scan`.
4. Ensure that the file scheduled detection switch is `turned on`, and that the detection cycle, detection file path, and detection range are set.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Runtime Security` > `Virus Scanning`.
3. Click `Detection settings` > `Scheduled Scan`.
4. `Enable` the file timing detection switch, set the detection cycle, file path, and detection scope.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1163/50909

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

9.10 Ensure Mirror Interception policy is configured (Manual)

Profile Applicability:

- Level 1

Description:

Configure the mirror interception policy to automatically block container images that contain high-risk vulnerabilities, privileged configurations, or other security concerns before they are deployed to runtime environments. This ensures that only secure and compliant images are allowed to enter the container ecosystem, protecting clusters and workloads from potential compromise.

Rationale:

Proactively intercepting vulnerable or misconfigured images prevents insecure images from being deployed, reducing the risk of runtime attacks, lateral movement, and unauthorized access. By enforcing image security policies, organizations can maintain a safer container environment and uphold compliance standards, ensuring production workloads are protected from preventable security risks.

Impact:

Configuring Mirror Interception policy may incur additional charges.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Policy Management` > `Image Blocking Policies`.
3. Ensure that the image interception policy has been `created` and `enabled`.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Policy Management` > `Image Blocking Policies`.
3. `Create` and `enable` the mirroring interception policy.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1163/63247

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

9.11 Ensure notification is enabled for all high-risk security activities (Manual)

Profile Applicability:

- Level 1

Description:

For serious or high-risk security risks, ensure that multiple notification channels such as internal messages, text messages, and emails are properly configured and enabled.

Rationale:

Timely alerts allow security operations personnel to respond quickly to security incidents, reducing potential impact and mitigating damage.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Alert Policies`.
3. Ensure that the alarm switches for each alarm type are `turned on` and that the alarm time, alarm host range, and alarm items are configured.
4. Click `Message Center` > `Message Subscription` to ensure that the container security message reception channel has been set up.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Alert Policies`.
3. `Enable` the alarm switches for each alarm type, configure the alarm time, alarm host range, and alarm items.
4. Click `Message Center` > `Message Subscription` to configure the container security message reception channel.

Default Value:

Only some alert types have notifications enabled by default.

References:

1. https://www.tencentcloud.com/document/product/1163/50925

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.1 Centralize Security Event Alerting Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.		●	●
v7	6.6 Deploy SIEM or Log Analytic tool Deploy Security Information and Event Management (SIEM) or log analytic tool for log correlation and analysis.		●	●

9.12 Ensure log analysis is enabled (Manual)

Profile Applicability:

- Level 1

Description:

Container security log storage, including asset logs, client-reported logs, and risk/alert logs, with a storage duration of no less than six months.

Rationale:

Centralized log storage and analysis help meet security audit and compliance requirements, and provide reliable evidence for event investigation and tracing.

Impact:

Enabling log storage and analysis may incur additional charges for the service.

Audit:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Log Analysis`.
3. Click `Log Configuration`.
4. Ensure that the configuration is stored.

Remediation:

Using the Management Console:

1. Log in to the Container Security Console.
2. Select `Log Analysis`.
3. Click `Buy Now` to proceed to the container security purchase page.
4. Select the log analysis storage capacity, with a storage duration of no less than 6 months, and complete the order and payment.
5. Return to `Log Analysis`.
6. Click `Log Configuration`.
7. Configure log storage content and log cleanup settings.

Default Value:

Not configured.

References:

1. https://www.tencentcloud.com/document/product/1163/50927

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	**Identity and Access Management**		
1.1	Avoid the use of the "root" account (Manual)	☐	☐
1.2	Ensure no root account access key exists (Manual)	☐	☐
1.3	Ensure Multi-factor Authentication is enabled for the "root" account (Manual)	☐	☐
1.4	Ensure that multi-factor authentication is enabled for all CAM users that have a console password (Manual)	☐	☐
1.5	Ensure users not logged on for 90 days or longer are disabled for console logon (Manual)	☐	☐
1.6	Ensure access keys are rotated every 90 days or less (Manual)	☐	☐
1.7	Ensure CAM password policy requires at least one uppercase letter (Manual)	☐	☐
1.8	Ensure CAM password policy requires at least one lowercase letter (Manual)	☐	☐
1.9	Ensure CAM password policy require at least one special character (Manual)	☐	☐
1.10	Ensure CAM password policy require at least one digit (Manual)	☐	☐
1.11	Ensure CAM password policy requires minimum length of 14 or greater (Manual)	☐	☐
1.12	Ensure CAM password policy prevents password reuse (Automated)	☐	☐
1.13	Ensure CAM password policy expires passwords in 365 days (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.14	Ensure CAM password policy temporarily blocks logon after 5 incorrect logon attempts within an hour (Automated)	☐	☐
1.15	Ensure CAM policies that allow full "*:*" administrative privileges are not created (Manual)	☐	☐
1.16	Ensure CAM policies are attached only to groups or roles (Manual)	☐	☐
2	**Logging and Monitoring**		
2.1	Ensure that CloudAudit is configured to export all operational log records (Manual)	☐	☐
2.2	Ensure the COS used to store CloudAudit logs is not publicly accessible (Manual)	☐	☐
2.3	Ensure audit logs for multiple cloud resources are integrated with Cloud Log Service (Manual)	☐	☐
2.4	Ensure virtual network flow log service is enabled (Manual)	☐	☐
2.5	Ensure EdgeOne log service is enabled (Manual)	☐	☐
2.6	Ensure Web Application Firewall access and security log service is enabled (Manual)	☐	☐
2.7	Ensure Cloud Firewall access and security log service is enabled (Manual)	☐	☐
2.8	Ensure Cloud Security Center Cloud Firewall, Web Application Firewall and Host Security log analysis is enabled (Manual)	☐	☐
2.9	Ensure log monitoring and alerts are set up for CAM Role changes (Manual)	☐	☐
2.10	Ensure log monitoring and alerts are set up for Cloud Firewall changes (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.11	Ensure log monitoring and alerts are set up for VPC network route changes (Manual)	☐	☐
2.12	Ensure log monitoring and alerts are set up for VPC changes (Manual)	☐	☐
2.13	Ensure log monitoring and alerts are set up for COS permission changes (Manual)	☐	☐
2.14	Ensure log monitoring and alerts are set up for CDB instance configuration changes (Manual)	☐	☐
2.15	Ensure a log monitoring and alerts are set up to monitor Management Console sign-in without MFA (Manual)	☐	☐
2.16	Ensure a log monitoring and alerts are set up to monitor the usage of "root" account (Manual)	☐	☐
2.17	Ensure a log monitoring and alerts are set up to monitor disabling or deletion of customer created CMKs (Manual)	☐	☐
2.18	Ensure a log monitoring and alerts are set up to monitor COS bucket policy changes (Manual)	☐	☐
2.19	Ensure a log monitoring and alerts are set up to monitor security group changes (Manual)	☐	☐
2.20	Ensure that Logstore data retention period is set 365 days or greater (Automated)	☐	☐
3	**Networking**		
3.1	Ensure that remote access is restricted from the internet (Manual)	☐	☐
3.2	Ensure virtual network flow log service is enabled (Manual)	☐	☐
3.3	Ensure routing tables for VPC peering are "least access" (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
3.4	Ensure the security groups are configured with fine grained rules (Manual)	☐	☐
3.5	Ensure no security groups allow ingress from 0.0.0.0/0 to port 22 (Manual)	☐	☐
3.6	Ensure no security groups allow ingress from 0.0.0.0/0 to port 3389 (Manual)	☐	☐
3.7	Ensure a Cloud Load Balancer security group is created to isolate public network traffic. (Manual)	☐	☐
4	**Storage**		
4.1	Ensure that COS bucket is not anonymously or publicly accessible (Automated)	☐	☐
4.2	Ensure that there are no publicly accessible objects in storage buckets (Manual)	☐	☐
4.3	Ensure that logging is enabled for COS buckets (Automated)	☐	☐
4.4	Ensure that 'Secure transfer required' is set to 'Enabled' (Automated)	☐	☐
4.5	Ensure network access rules for COS buckets are not set to publicly accessible (Automated)	☐	☐
4.6	Ensure server-side encryption is set to SSE-COS (Manual)	☐	☐
4.7	Ensure server-side encryption is set to SSE-KMS (Manual)	☐	☐
4.8	Ensure that 'Unattached disks' are encrypted (Manual)	☐	☐
4.9	Ensure that ‘Virtual Machine's disk’ are encrypted (Manual)	☐	☐
5	**Relational Database TencentDB for MySQL**		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.1	Ensure TencentDB for MySQL instance requires all incoming connections to use SSL (Automated)	☐	☐
5.2	Ensure TencentDB for MySQL instance does not allow public access (Automated)	☐	☐
5.3	Ensure the ‘Audit Function’ for TencentDB for MySQL instance is set to ‘Enabled’ (Automated)	☐	☐
5.4	Ensure 'Auditing Retention’ for TencentDB for MySQL instance is greater than 6 months (Automated)	☐	☐
5.5	Ensure TencentDB for MySQL instance has TDE (Transparent Data Encryption) set to ‘Enabled’ (Manual)	☐	☐
5.6	Ensure the TDE (Transparent Data Encryption) protector of theTencentDB for MySQL instance uses BYOK (Bring Your Own Key) encryption (Automated)	☐	☐
6	**Kubernetes Engine**		
6.1	Ensure Cluster Audit is set to ‘Enabled’ on Kubernetes Engine Clusters (Automated)	☐	☐
6.2	Ensure Cloud Monitoring is set to Enabled on Kubernetes Engine Clusters (Automated)	☐	☐
6.3	Ensure role-based access control (RBAC) authorization is Enabled on Kubernetes Engine Clusters (Automated)	☐	☐
6.4	Ensure Cluster Health Check triggered at least once per week for Kubernetes Clusters (Automated)	☐	☐
6.5	Ensure Kubernetes web UI / Dashboard is not enabled (Automated)	☐	☐
6.6	Ensure Basic Authentication is not ‘Enabled’ on Kubernetes Engine Clusters (Automated)	☐	☐
6.7	Ensure Network policy is ‘Enabled’ on Kubernetes Engine Clusters (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
6.8	Ensure VPC-CNI Mode support for Kubernetes Cluster (Automated)	☐	☐
6.9	Ensure Kubernetes Cluster Internet Access is not 'Enabled' (Automated)	☐	☐
7	**Cloud Security Center**		
7.1	Ensure Cloud Security Center is Premium, Enterprise or Ultimate Edition (Manual)	☐	☐
7.2	Ensure cloud API exception monitoring is enabled (Manual)	☐	☐
7.3	Ensure member accounts are linked to a group account (Manual)	☐	☐
7.4	Ensure periodic security check tasks are configured (Manual)	☐	☐
7.5	Ensure notification is enabled for high-risk security activities (Manual)	☐	☐
7.6	Ensure log storage analysis is enabled (Manual)	☐	☐
8	**Cloud Workload Protection Platform**		
8.1	Ensure CVM server has installed Cloud Workload Protection Platform(CWPP) Agent (Automated)	☐	☐
8.2	Ensure CVM server has installed the Cloud Workload Protection Platform(CWPP) Professional or Ultimate edition agent (Automated)	☐	☐
8.3	Ensure that the Cloud Workload Protection Platform(CWPP) application protection switch is 'Turn on' (Manual)	☐	☐
8.4	Ensure CWPP agent 'self-protection', 'scheduled scanning', and 'automatic defense' are 'Enabled' (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
8.5	Ensure notification is enabled for all high-risk security activities (Manual)	☐	☐
8.6	Ensure log storage analysis is enabled (Manual)	☐	☐
9	**Tencent Container Security Service**		
9.1	Ensure Container Security protection is enabled for clusters and hosts (Automated)	☐	☐
9.2	Ensure Image Scan is Enabled (Manual)	☐	☐
9.3	Ensure TCSS application protection switch is 'Turn on' (Manual)	☐	☐
9.4	Ensure Container Asset has installed Container Security Agent (Manual)	☐	☐
9.5	Ensure Scheduled Image Scanning is Configured (Automated)	☐	☐
9.6	Ensure Automatic Cluster Check is ‘Enabled’ (Manual)	☐	☐
9.7	Ensure Vulnerability Scanning is enabled (Manual)	☐	☐
9.8	Ensure Baseline Cycle Detection is Enabled (Manual)	☐	☐
9.9	Ensure Virus Scanning is Enabled (Automated)	☐	☐
9.10	Ensure Mirror Interception policy is configured (Manual)	☐	☐
9.11	Ensure notification is enabled for all high-risk security activities (Manual)	☐	☐
9.12	Ensure log analysis is enabled (Manual)	☐	☐

Appendix: CIS Controls v7 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Avoid the use of the "root" account	☐	☐
1.2	Ensure no root account access key exists	☐	☐
1.5	Ensure users not logged on for 90 days or longer are disabled for console logon	☐	☐
2.1	Ensure that CloudAudit is configured to export all operational log records	☐	☐
2.3	Ensure audit logs for multiple cloud resources are integrated with Cloud Log Service	☐	☐
2.4	Ensure virtual network flow log service is enabled	☐	☐
2.5	Ensure EdgeOne log service is enabled	☐	☐
2.6	Ensure Web Application Firewall access and security log service is enabled	☐	☐
2.7	Ensure Cloud Firewall access and security log service is enabled	☐	☐
2.8	Ensure Cloud Security Center Cloud Firewall, Web Application Firewall and Host Security log analysis is enabled	☐	☐
2.9	Ensure log monitoring and alerts are set up for CAM Role changes	☐	☐
2.10	Ensure log monitoring and alerts are set up for Cloud Firewall changes	☐	☐
2.11	Ensure log monitoring and alerts are set up for VPC network route changes	☐	☐
2.12	Ensure log monitoring and alerts are set up for VPC changes	☐	☐
2.13	Ensure log monitoring and alerts are set up for COS permission changes	☐	☐
2.14	Ensure log monitoring and alerts are set up for CDB instance configuration changes	☐	☐
2.15	Ensure a log monitoring and alerts are set up to monitor Management Console sign-in without MFA	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.17	Ensure a log monitoring and alerts are set up to monitor disabling or deletion of customer created CMKs	☐	☐
2.18	Ensure a log monitoring and alerts are set up to monitor COS bucket policy changes	☐	☐
3.1	Ensure that remote access is restricted from the internet	☐	☐
3.2	Ensure virtual network flow log service is enabled	☐	☐
3.3	Ensure routing tables for VPC peering are "least access"	☐	☐
3.4	Ensure the security groups are configured with fine grained rules	☐	☐
3.5	Ensure no security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
3.6	Ensure no security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
4.1	Ensure that COS bucket is not anonymously or publicly accessible	☐	☐
4.2	Ensure that there are no publicly accessible objects in storage buckets	☐	☐
4.3	Ensure that logging is enabled for COS buckets	☐	☐
5.2	Ensure TencentDB for MySQL instance does not allow public access	☐	☐
5.3	Ensure the ‘Audit Function’ for TencentDB for MySQL instance is set to ‘Enabled’	☐	☐
6.1	Ensure Cluster Audit is set to ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.2	Ensure Cloud Monitoring is set to Enabled on Kubernetes Engine Clusters	☐	☐
6.5	Ensure Kubernetes web UI / Dashboard is not enabled	☐	☐
7.6	Ensure log storage analysis is enabled	☐	☐
8.6	Ensure log storage analysis is enabled	☐	☐
9.12	Ensure log analysis is enabled	☐	☐

Appendix: CIS Controls v7 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Avoid the use of the "root" account	☐	☐
1.2	Ensure no root account access key exists	☐	☐
1.3	Ensure Multi-factor Authentication is enabled for the "root" account	☐	☐
1.4	Ensure that multi-factor authentication is enabled for all CAM users that have a console password	☐	☐
1.5	Ensure users not logged on for 90 days or longer are disabled for console logon	☐	☐
1.7	Ensure CAM password policy requires at least one uppercase letter	☐	☐
1.8	Ensure CAM password policy requires at least one lowercase letter	☐	☐
1.9	Ensure CAM password policy require at least one special character	☐	☐
1.10	Ensure CAM password policy require at least one digit	☐	☐
1.11	Ensure CAM password policy requires minimum length of 14 or greater	☐	☐
1.12	Ensure CAM password policy prevents password reuse	☐	☐
2.1	Ensure that CloudAudit is configured to export all operational log records	☐	☐
2.2	Ensure the COS used to store CloudAudit logs is not publicly accessible	☐	☐
2.3	Ensure audit logs for multiple cloud resources are integrated with Cloud Log Service	☐	☐
2.4	Ensure virtual network flow log service is enabled	☐	☐
2.5	Ensure EdgeOne log service is enabled	☐	☐
2.6	Ensure Web Application Firewall access and security log service is enabled	☐	☐
2.7	Ensure Cloud Firewall access and security log service is enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.8	Ensure Cloud Security Center Cloud Firewall, Web Application Firewall and Host Security log analysis is enabled	☐	☐
2.9	Ensure log monitoring and alerts are set up for CAM Role changes	☐	☐
2.10	Ensure log monitoring and alerts are set up for Cloud Firewall changes	☐	☐
2.11	Ensure log monitoring and alerts are set up for VPC network route changes	☐	☐
2.12	Ensure log monitoring and alerts are set up for VPC changes	☐	☐
2.13	Ensure log monitoring and alerts are set up for COS permission changes	☐	☐
2.14	Ensure log monitoring and alerts are set up for CDB instance configuration changes	☐	☐
2.15	Ensure a log monitoring and alerts are set up to monitor Management Console sign-in without MFA	☐	☐
2.16	Ensure a log monitoring and alerts are set up to monitor the usage of "root" account	☐	☐
2.17	Ensure a log monitoring and alerts are set up to monitor disabling or deletion of customer created CMKs	☐	☐
2.18	Ensure a log monitoring and alerts are set up to monitor COS bucket policy changes	☐	☐
2.19	Ensure a log monitoring and alerts are set up to monitor security group changes	☐	☐
2.20	Ensure that Logstore data retention period is set 365 days or greater	☐	☐
3.1	Ensure that remote access is restricted from the internet	☐	☐
3.2	Ensure virtual network flow log service is enabled	☐	☐
3.3	Ensure routing tables for VPC peering are "least access"	☐	☐
3.4	Ensure the security groups are configured with fine grained rules	☐	☐
3.5	Ensure no security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
3.6	Ensure no security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐

Recommendation		Set Correctly	
		Yes	No
4.1	Ensure that COS bucket is not anonymously or publicly accessible	☐	☐
4.2	Ensure that there are no publicly accessible objects in storage buckets	☐	☐
4.3	Ensure that logging is enabled for COS buckets	☐	☐
4.4	Ensure that 'Secure transfer required' is set to 'Enabled'	☐	☐
4.5	Ensure network access rules for COS buckets are not set to publicly accessible	☐	☐
5.1	Ensure TencentDB for MySQL instance requires all incoming connections to use SSL	☐	☐
5.2	Ensure TencentDB for MySQL instance does not allow public access	☐	☐
5.3	Ensure the ‘Audit Function’ for TencentDB for MySQL instance is set to ‘Enabled’	☐	☐
5.4	Ensure 'Auditing Retention’ for TencentDB for MySQL instance is greater than 6 months	☐	☐
6.1	Ensure Cluster Audit is set to ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.2	Ensure Cloud Monitoring is set to Enabled on Kubernetes Engine Clusters	☐	☐
6.5	Ensure Kubernetes web UI / Dashboard is not enabled	☐	☐
6.6	Ensure Basic Authentication is not ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.7	Ensure Network policy is ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.8	Ensure VPC-CNI Mode support for Kubernetes Cluster	☐	☐
6.9	Ensure Kubernetes Cluster Internet Access is not ‘Enabled’	☐	☐
7.1	Ensure Cloud Security Center is Premium, Enterprise or Ultimate Edition	☐	☐
7.4	Ensure periodic security check tasks are configured	☐	☐
7.5	Ensure notification is enabled for high-risk security activities	☐	☐
7.6	Ensure log storage analysis is enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
8.1	Ensure CVM server has installed Cloud Workload Protection Platform(CWPP) Agent	☐	☐
8.2	Ensure CVM server has installed the Cloud Workload Protection Platform(CWPP) Professional or Ultimate edition agent	☐	☐
8.3	Ensure that the Cloud Workload Protection Platform(CWPP) application protection switch is ‘Turn on’	☐	☐
8.4	Ensure CWPP agent ‘self-protection’, ‘scheduled scanning’, and ‘automatic defense’ are ‘Enabled’	☐	☐
8.5	Ensure notification is enabled for all high-risk security activities	☐	☐
8.6	Ensure log storage analysis is enabled	☐	☐
9.1	Ensure Container Security protection is enabled for clusters and hosts	☐	☐
9.2	Ensure Image Scan is Enabled	☐	☐
9.3	Ensure TCSS application protection switch is 'Turn on'	☐	☐
9.4	Ensure Container Asset has installed Container Security Agent	☐	☐
9.5	Ensure Scheduled Image Scanning is Configured	☐	☐
9.6	Ensure Automatic Cluster Check is ‘Enabled’	☐	☐
9.7	Ensure Vulnerability Scanning is enabled	☐	☐
9.9	Ensure Virus Scanning is Enabled	☐	☐
9.11	Ensure notification is enabled for all high-risk security activities	☐	☐
9.12	Ensure log analysis is enabled	☐	☐

Appendix: CIS Controls v7 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Avoid the use of the "root" account	☐	☐
1.2	Ensure no root account access key exists	☐	☐
1.3	Ensure Multi-factor Authentication is enabled for the "root" account	☐	☐
1.4	Ensure that multi-factor authentication is enabled for all CAM users that have a console password	☐	☐
1.5	Ensure users not logged on for 90 days or longer are disabled for console logon	☐	☐
1.7	Ensure CAM password policy requires at least one uppercase letter	☐	☐
1.8	Ensure CAM password policy requires at least one lowercase letter	☐	☐
1.9	Ensure CAM password policy require at least one special character	☐	☐
1.10	Ensure CAM password policy require at least one digit	☐	☐
1.11	Ensure CAM password policy requires minimum length of 14 or greater	☐	☐
1.12	Ensure CAM password policy prevents password reuse	☐	☐
2.1	Ensure that CloudAudit is configured to export all operational log records	☐	☐
2.2	Ensure the COS used to store CloudAudit logs is not publicly accessible	☐	☐
2.3	Ensure audit logs for multiple cloud resources are integrated with Cloud Log Service	☐	☐
2.4	Ensure virtual network flow log service is enabled	☐	☐
2.5	Ensure EdgeOne log service is enabled	☐	☐
2.6	Ensure Web Application Firewall access and security log service is enabled	☐	☐
2.7	Ensure Cloud Firewall access and security log service is enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.8	Ensure Cloud Security Center Cloud Firewall, Web Application Firewall and Host Security log analysis is enabled	☐	☐
2.9	Ensure log monitoring and alerts are set up for CAM Role changes	☐	☐
2.10	Ensure log monitoring and alerts are set up for Cloud Firewall changes	☐	☐
2.11	Ensure log monitoring and alerts are set up for VPC network route changes	☐	☐
2.12	Ensure log monitoring and alerts are set up for VPC changes	☐	☐
2.13	Ensure log monitoring and alerts are set up for COS permission changes	☐	☐
2.14	Ensure log monitoring and alerts are set up for CDB instance configuration changes	☐	☐
2.15	Ensure a log monitoring and alerts are set up to monitor Management Console sign-in without MFA	☐	☐
2.16	Ensure a log monitoring and alerts are set up to monitor the usage of "root" account	☐	☐
2.17	Ensure a log monitoring and alerts are set up to monitor disabling or deletion of customer created CMKs	☐	☐
2.18	Ensure a log monitoring and alerts are set up to monitor COS bucket policy changes	☐	☐
2.19	Ensure a log monitoring and alerts are set up to monitor security group changes	☐	☐
2.20	Ensure that Logstore data retention period is set 365 days or greater	☐	☐
3.1	Ensure that remote access is restricted from the internet	☐	☐
3.2	Ensure virtual network flow log service is enabled	☐	☐
3.3	Ensure routing tables for VPC peering are "least access"	☐	☐
3.4	Ensure the security groups are configured with fine grained rules	☐	☐
3.5	Ensure no security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
3.6	Ensure no security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐

Recommendation		Set Correctly	
		Yes	No
4.1	Ensure that COS bucket is not anonymously or publicly accessible	☐	☐
4.2	Ensure that there are no publicly accessible objects in storage buckets	☐	☐
4.3	Ensure that logging is enabled for COS buckets	☐	☐
4.4	Ensure that 'Secure transfer required' is set to 'Enabled'	☐	☐
4.5	Ensure network access rules for COS buckets are not set to publicly accessible	☐	☐
4.6	Ensure server-side encryption is set to SSE-COS	☐	☐
4.7	Ensure server-side encryption is set to SSE-KMS	☐	☐
4.8	Ensure that 'Unattached disks' are encrypted	☐	☐
4.9	Ensure that ‘Virtual Machine's disk’ are encrypted	☐	☐
5.1	Ensure TencentDB for MySQL instance requires all incoming connections to use SSL	☐	☐
5.2	Ensure TencentDB for MySQL instance does not allow public access	☐	☐
5.3	Ensure the ‘Audit Function’ for TencentDB for MySQL instance is set to ‘Enabled’	☐	☐
5.4	Ensure 'Auditing Retention’ for TencentDB for MySQL instance is greater than 6 months	☐	☐
5.5	Ensure TencentDB for MySQL instance has TDE (Transparent Data Encryption) set to ‘Enabled’	☐	☐
5.6	Ensure the TDE (Transparent Data Encryption) protector of theTencentDB for MySQL instance uses BYOK (Bring Your Own Key) encryption	☐	☐
6.1	Ensure Cluster Audit is set to ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.2	Ensure Cloud Monitoring is set to Enabled on Kubernetes Engine Clusters	☐	☐
6.5	Ensure Kubernetes web UI / Dashboard is not enabled	☐	☐
6.6	Ensure Basic Authentication is not ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.7	Ensure Network policy is ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.8	Ensure VPC-CNI Mode support for Kubernetes Cluster	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.9	Ensure Kubernetes Cluster Internet Access is not ‘Enabled’	☐	☐
7.1	Ensure Cloud Security Center is Premium, Enterprise or Ultimate Edition	☐	☐
7.4	Ensure periodic security check tasks are configured	☐	☐
7.5	Ensure notification is enabled for high-risk security activities	☐	☐
7.6	Ensure log storage analysis is enabled	☐	☐
8.1	Ensure CVM server has installed Cloud Workload Protection Platform(CWPP) Agent	☐	☐
8.2	Ensure CVM server has installed the Cloud Workload Protection Platform(CWPP) Professional or Ultimate edition agent	☐	☐
8.3	Ensure that the Cloud Workload Protection Platform(CWPP) application protection switch is ‘Turn on’	☐	☐
8.4	Ensure CWPP agent ‘self-protection’, ‘scheduled scanning’, and ‘automatic defense’ are ‘Enabled’	☐	☐
8.5	Ensure notification is enabled for all high-risk security activities	☐	☐
8.6	Ensure log storage analysis is enabled	☐	☐
9.1	Ensure Container Security protection is enabled for clusters and hosts	☐	☐
9.2	Ensure Image Scan is Enabled	☐	☐
9.3	Ensure TCSS application protection switch is 'Turn on'	☐	☐
9.4	Ensure Container Asset has installed Container Security Agent	☐	☐
9.5	Ensure Scheduled Image Scanning is Configured	☐	☐
9.6	Ensure Automatic Cluster Check is ‘Enabled’	☐	☐
9.7	Ensure Vulnerability Scanning is enabled	☐	☐
9.9	Ensure Virus Scanning is Enabled	☐	☐
9.11	Ensure notification is enabled for all high-risk security activities	☐	☐
9.12	Ensure log analysis is enabled	☐	☐

Appendix: CIS Controls v7 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
6.4	Ensure Cluster Health Check triggered at least once per week for Kubernetes Clusters	☐	☐

Appendix: CIS Controls v8 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Avoid the use of the "root" account	☐	☐
1.2	Ensure no root account access key exists	☐	☐
1.3	Ensure Multi-factor Authentication is enabled for the "root" account	☐	☐
1.5	Ensure users not logged on for 90 days or longer are disabled for console logon	☐	☐
1.7	Ensure CAM password policy requires at least one uppercase letter	☐	☐
1.8	Ensure CAM password policy requires at least one lowercase letter	☐	☐
1.9	Ensure CAM password policy require at least one special character	☐	☐
1.10	Ensure CAM password policy require at least one digit	☐	☐
1.11	Ensure CAM password policy requires minimum length of 14 or greater	☐	☐
1.12	Ensure CAM password policy prevents password reuse	☐	☐
1.15	Ensure CAM policies that allow full "*:*" administrative privileges are not created	☐	☐
2.1	Ensure that CloudAudit is configured to export all operational log records	☐	☐
2.2	Ensure the COS used to store CloudAudit logs is not publicly accessible	☐	☐
2.3	Ensure audit logs for multiple cloud resources are integrated with Cloud Log Service	☐	☐
2.4	Ensure virtual network flow log service is enabled	☐	☐
2.5	Ensure EdgeOne log service is enabled	☐	☐
2.6	Ensure Web Application Firewall access and security log service is enabled	☐	☐
2.7	Ensure Cloud Firewall access and security log service is enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.8	Ensure Cloud Security Center Cloud Firewall, Web Application Firewall and Host Security log analysis is enabled	☐	☐
2.9	Ensure log monitoring and alerts are set up for CAM Role changes	☐	☐
2.10	Ensure log monitoring and alerts are set up for Cloud Firewall changes	☐	☐
2.11	Ensure log monitoring and alerts are set up for VPC network route changes	☐	☐
2.12	Ensure log monitoring and alerts are set up for VPC changes	☐	☐
2.13	Ensure log monitoring and alerts are set up for COS permission changes	☐	☐
2.14	Ensure log monitoring and alerts are set up for CDB instance configuration changes	☐	☐
2.15	Ensure a log monitoring and alerts are set up to monitor Management Console sign-in without MFA	☐	☐
2.17	Ensure a log monitoring and alerts are set up to monitor disabling or deletion of customer created CMKs	☐	☐
2.18	Ensure a log monitoring and alerts are set up to monitor COS bucket policy changes	☐	☐
2.20	Ensure that Logstore data retention period is set 365 days or greater	☐	☐
3.1	Ensure that remote access is restricted from the internet	☐	☐
3.2	Ensure virtual network flow log service is enabled	☐	☐
3.3	Ensure routing tables for VPC peering are "least access"	☐	☐
3.4	Ensure the security groups are configured with fine grained rules	☐	☐
3.5	Ensure no security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
3.6	Ensure no security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
3.7	Ensure a Cloud Load Balancer security group is created to isolate public network traffic.	☐	☐
4.1	Ensure that COS bucket is not anonymously or publicly accessible	☐	☐

Recommendation		Set Correctly	
		Yes	No
4.2	Ensure that there are no publicly accessible objects in storage buckets	☐	☐
4.3	Ensure that logging is enabled for COS buckets	☐	☐
5.2	Ensure TencentDB for MySQL instance does not allow public access	☐	☐
5.3	Ensure the ‘Audit Function’ for TencentDB for MySQL instance is set to ‘Enabled’	☐	☐
5.4	Ensure 'Auditing Retention’ for TencentDB for MySQL instance is greater than 6 months	☐	☐
6.1	Ensure Cluster Audit is set to ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.2	Ensure Cloud Monitoring is set to Enabled on Kubernetes Engine Clusters	☐	☐
6.5	Ensure Kubernetes web UI / Dashboard is not enabled	☐	☐
7.6	Ensure log storage analysis is enabled	☐	☐
8.1	Ensure CVM server has installed Cloud Workload Protection Platform(CWPP) Agent	☐	☐
8.2	Ensure CVM server has installed the Cloud Workload Protection Platform(CWPP) Professional or Ultimate edition agent	☐	☐
8.3	Ensure that the Cloud Workload Protection Platform(CWPP) application protection switch is ‘Turn on’	☐	☐
8.4	Ensure CWPP agent ‘self-protection’, ‘scheduled scanning’, and ‘automatic defense’ are ‘Enabled’	☐	☐
8.6	Ensure log storage analysis is enabled	☐	☐
9.1	Ensure Container Security protection is enabled for clusters and hosts	☐	☐
9.2	Ensure Image Scan is Enabled	☐	☐
9.3	Ensure TCSS application protection switch is 'Turn on'	☐	☐
9.4	Ensure Container Asset has installed Container Security Agent	☐	☐
9.5	Ensure Scheduled Image Scanning is Configured	☐	☐
9.9	Ensure Virus Scanning is Enabled	☐	☐
9.12	Ensure log analysis is enabled	☐	☐

Appendix: CIS Controls v8 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Avoid the use of the "root" account	☐	☐
1.2	Ensure no root account access key exists	☐	☐
1.3	Ensure Multi-factor Authentication is enabled for the "root" account	☐	☐
1.4	Ensure that multi-factor authentication is enabled for all CAM users that have a console password	☐	☐
1.5	Ensure users not logged on for 90 days or longer are disabled for console logon	☐	☐
1.7	Ensure CAM password policy requires at least one uppercase letter	☐	☐
1.8	Ensure CAM password policy requires at least one lowercase letter	☐	☐
1.9	Ensure CAM password policy require at least one special character	☐	☐
1.10	Ensure CAM password policy require at least one digit	☐	☐
1.11	Ensure CAM password policy requires minimum length of 14 or greater	☐	☐
1.12	Ensure CAM password policy prevents password reuse	☐	☐
1.15	Ensure CAM policies that allow full "*:*" administrative privileges are not created	☐	☐
2.1	Ensure that CloudAudit is configured to export all operational log records	☐	☐
2.2	Ensure the COS used to store CloudAudit logs is not publicly accessible	☐	☐
2.3	Ensure audit logs for multiple cloud resources are integrated with Cloud Log Service	☐	☐
2.4	Ensure virtual network flow log service is enabled	☐	☐
2.5	Ensure EdgeOne log service is enabled	☐	☐
2.6	Ensure Web Application Firewall access and security log service is enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.7	Ensure Cloud Firewall access and security log service is enabled	☐	☐
2.8	Ensure Cloud Security Center Cloud Firewall, Web Application Firewall and Host Security log analysis is enabled	☐	☐
2.9	Ensure log monitoring and alerts are set up for CAM Role changes	☐	☐
2.10	Ensure log monitoring and alerts are set up for Cloud Firewall changes	☐	☐
2.11	Ensure log monitoring and alerts are set up for VPC network route changes	☐	☐
2.12	Ensure log monitoring and alerts are set up for VPC changes	☐	☐
2.13	Ensure log monitoring and alerts are set up for COS permission changes	☐	☐
2.14	Ensure log monitoring and alerts are set up for CDB instance configuration changes	☐	☐
2.15	Ensure a log monitoring and alerts are set up to monitor Management Console sign-in without MFA	☐	☐
2.16	Ensure a log monitoring and alerts are set up to monitor the usage of "root" account	☐	☐
2.17	Ensure a log monitoring and alerts are set up to monitor disabling or deletion of customer created CMKs	☐	☐
2.18	Ensure a log monitoring and alerts are set up to monitor COS bucket policy changes	☐	☐
2.19	Ensure a log monitoring and alerts are set up to monitor security group changes	☐	☐
2.20	Ensure that Logstore data retention period is set 365 days or greater	☐	☐
3.1	Ensure that remote access is restricted from the internet	☐	☐
3.2	Ensure virtual network flow log service is enabled	☐	☐
3.3	Ensure routing tables for VPC peering are "least access"	☐	☐
3.4	Ensure the security groups are configured with fine grained rules	☐	☐
3.5	Ensure no security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.6	Ensure no security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
3.7	Ensure a Cloud Load Balancer security group is created to isolate public network traffic.	☐	☐
4.1	Ensure that COS bucket is not anonymously or publicly accessible	☐	☐
4.2	Ensure that there are no publicly accessible objects in storage buckets	☐	☐
4.3	Ensure that logging is enabled for COS buckets	☐	☐
4.4	Ensure that 'Secure transfer required' is set to 'Enabled'	☐	☐
4.5	Ensure network access rules for COS buckets are not set to publicly accessible	☐	☐
4.6	Ensure server-side encryption is set to SSE-COS	☐	☐
4.7	Ensure server-side encryption is set to SSE-KMS	☐	☐
4.8	Ensure that 'Unattached disks' are encrypted	☐	☐
4.9	Ensure that ‘Virtual Machine's disk’ are encrypted	☐	☐
5.1	Ensure TencentDB for MySQL instance requires all incoming connections to use SSL	☐	☐
5.2	Ensure TencentDB for MySQL instance does not allow public access	☐	☐
5.3	Ensure the ‘Audit Function’ for TencentDB for MySQL instance is set to ‘Enabled’	☐	☐
5.4	Ensure 'Auditing Retention’ for TencentDB for MySQL instance is greater than 6 months	☐	☐
5.5	Ensure TencentDB for MySQL instance has TDE (Transparent Data Encryption) set to ‘Enabled’	☐	☐
5.6	Ensure the TDE (Transparent Data Encryption) protector of theTencentDB for MySQL instance uses BYOK (Bring Your Own Key) encryption	☐	☐
6.1	Ensure Cluster Audit is set to ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.2	Ensure Cloud Monitoring is set to Enabled on Kubernetes Engine Clusters	☐	☐
6.5	Ensure Kubernetes web UI / Dashboard is not enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.6	Ensure Basic Authentication is not ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.7	Ensure Network policy is ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.8	Ensure VPC-CNI Mode support for Kubernetes Cluster	☐	☐
6.9	Ensure Kubernetes Cluster Internet Access is not ‘Enabled’	☐	☐
7.1	Ensure Cloud Security Center is Premium, Enterprise or Ultimate Edition	☐	☐
7.4	Ensure periodic security check tasks are configured	☐	☐
7.5	Ensure notification is enabled for high-risk security activities	☐	☐
7.6	Ensure log storage analysis is enabled	☐	☐
8.1	Ensure CVM server has installed Cloud Workload Protection Platform(CWPP) Agent	☐	☐
8.2	Ensure CVM server has installed the Cloud Workload Protection Platform(CWPP) Professional or Ultimate edition agent	☐	☐
8.3	Ensure that the Cloud Workload Protection Platform(CWPP) application protection switch is ‘Turn on’	☐	☐
8.4	Ensure CWPP agent ‘self-protection’, ‘scheduled scanning’, and ‘automatic defense’ are ‘Enabled’	☐	☐
8.5	Ensure notification is enabled for all high-risk security activities	☐	☐
8.6	Ensure log storage analysis is enabled	☐	☐
9.1	Ensure Container Security protection is enabled for clusters and hosts	☐	☐
9.2	Ensure Image Scan is Enabled	☐	☐
9.3	Ensure TCSS application protection switch is 'Turn on'	☐	☐
9.4	Ensure Container Asset has installed Container Security Agent	☐	☐
9.5	Ensure Scheduled Image Scanning is Configured	☐	☐
9.6	Ensure Automatic Cluster Check is ‘Enabled’	☐	☐
9.7	Ensure Vulnerability Scanning is enabled	☐	☐
9.9	Ensure Virus Scanning is Enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
9.11	Ensure notification is enabled for all high-risk security activities	☐	☐
9.12	Ensure log analysis is enabled	☐	☐

Appendix: CIS Controls v8 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Avoid the use of the "root" account	☐	☐
1.2	Ensure no root account access key exists	☐	☐
1.3	Ensure Multi-factor Authentication is enabled for the "root" account	☐	☐
1.4	Ensure that multi-factor authentication is enabled for all CAM users that have a console password	☐	☐
1.5	Ensure users not logged on for 90 days or longer are disabled for console logon	☐	☐
1.7	Ensure CAM password policy requires at least one uppercase letter	☐	☐
1.8	Ensure CAM password policy requires at least one lowercase letter	☐	☐
1.9	Ensure CAM password policy require at least one special character	☐	☐
1.10	Ensure CAM password policy require at least one digit	☐	☐
1.11	Ensure CAM password policy requires minimum length of 14 or greater	☐	☐
1.12	Ensure CAM password policy prevents password reuse	☐	☐
1.15	Ensure CAM policies that allow full "*:*" administrative privileges are not created	☐	☐
2.1	Ensure that CloudAudit is configured to export all operational log records	☐	☐
2.2	Ensure the COS used to store CloudAudit logs is not publicly accessible	☐	☐
2.3	Ensure audit logs for multiple cloud resources are integrated with Cloud Log Service	☐	☐
2.4	Ensure virtual network flow log service is enabled	☐	☐
2.5	Ensure EdgeOne log service is enabled	☐	☐
2.6	Ensure Web Application Firewall access and security log service is enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.7	Ensure Cloud Firewall access and security log service is enabled	☐	☐
2.8	Ensure Cloud Security Center Cloud Firewall, Web Application Firewall and Host Security log analysis is enabled	☐	☐
2.9	Ensure log monitoring and alerts are set up for CAM Role changes	☐	☐
2.10	Ensure log monitoring and alerts are set up for Cloud Firewall changes	☐	☐
2.11	Ensure log monitoring and alerts are set up for VPC network route changes	☐	☐
2.12	Ensure log monitoring and alerts are set up for VPC changes	☐	☐
2.13	Ensure log monitoring and alerts are set up for COS permission changes	☐	☐
2.14	Ensure log monitoring and alerts are set up for CDB instance configuration changes	☐	☐
2.15	Ensure a log monitoring and alerts are set up to monitor Management Console sign-in without MFA	☐	☐
2.16	Ensure a log monitoring and alerts are set up to monitor the usage of "root" account	☐	☐
2.17	Ensure a log monitoring and alerts are set up to monitor disabling or deletion of customer created CMKs	☐	☐
2.18	Ensure a log monitoring and alerts are set up to monitor COS bucket policy changes	☐	☐
2.19	Ensure a log monitoring and alerts are set up to monitor security group changes	☐	☐
2.20	Ensure that Logstore data retention period is set 365 days or greater	☐	☐
3.1	Ensure that remote access is restricted from the internet	☐	☐
3.2	Ensure virtual network flow log service is enabled	☐	☐
3.3	Ensure routing tables for VPC peering are "least access"	☐	☐
3.4	Ensure the security groups are configured with fine grained rules	☐	☐
3.5	Ensure no security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.6	Ensure no security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
3.7	Ensure a Cloud Load Balancer security group is created to isolate public network traffic.	☐	☐
4.1	Ensure that COS bucket is not anonymously or publicly accessible	☐	☐
4.2	Ensure that there are no publicly accessible objects in storage buckets	☐	☐
4.3	Ensure that logging is enabled for COS buckets	☐	☐
4.4	Ensure that 'Secure transfer required' is set to 'Enabled'	☐	☐
4.5	Ensure network access rules for COS buckets are not set to publicly accessible	☐	☐
4.6	Ensure server-side encryption is set to SSE-COS	☐	☐
4.7	Ensure server-side encryption is set to SSE-KMS	☐	☐
4.8	Ensure that 'Unattached disks' are encrypted	☐	☐
4.9	Ensure that ‘Virtual Machine's disk’ are encrypted	☐	☐
5.1	Ensure TencentDB for MySQL instance requires all incoming connections to use SSL	☐	☐
5.2	Ensure TencentDB for MySQL instance does not allow public access	☐	☐
5.3	Ensure the ‘Audit Function’ for TencentDB for MySQL instance is set to ‘Enabled’	☐	☐
5.4	Ensure 'Auditing Retention’ for TencentDB for MySQL instance is greater than 6 months	☐	☐
5.5	Ensure TencentDB for MySQL instance has TDE (Transparent Data Encryption) set to ‘Enabled’	☐	☐
5.6	Ensure the TDE (Transparent Data Encryption) protector of theTencentDB for MySQL instance uses BYOK (Bring Your Own Key) encryption	☐	☐
6.1	Ensure Cluster Audit is set to ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.2	Ensure Cloud Monitoring is set to Enabled on Kubernetes Engine Clusters	☐	☐
6.3	Ensure role-based access control (RBAC) authorization is Enabled on Kubernetes Engine Clusters	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.5	Ensure Kubernetes web UI / Dashboard is not enabled	☐	☐
6.6	Ensure Basic Authentication is not ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.7	Ensure Network policy is ‘Enabled’ on Kubernetes Engine Clusters	☐	☐
6.8	Ensure VPC-CNI Mode support for Kubernetes Cluster	☐	☐
6.9	Ensure Kubernetes Cluster Internet Access is not ‘Enabled’	☐	☐
7.1	Ensure Cloud Security Center is Premium, Enterprise or Ultimate Edition	☐	☐
7.4	Ensure periodic security check tasks are configured	☐	☐
7.5	Ensure notification is enabled for high-risk security activities	☐	☐
7.6	Ensure log storage analysis is enabled	☐	☐
8.1	Ensure CVM server has installed Cloud Workload Protection Platform(CWPP) Agent	☐	☐
8.2	Ensure CVM server has installed the Cloud Workload Protection Platform(CWPP) Professional or Ultimate edition agent	☐	☐
8.3	Ensure that the Cloud Workload Protection Platform(CWPP) application protection switch is ‘Turn on’	☐	☐
8.4	Ensure CWPP agent ‘self-protection’, ‘scheduled scanning’, and ‘automatic defense’ are ‘Enabled’	☐	☐
8.5	Ensure notification is enabled for all high-risk security activities	☐	☐
8.6	Ensure log storage analysis is enabled	☐	☐
9.1	Ensure Container Security protection is enabled for clusters and hosts	☐	☐
9.2	Ensure Image Scan is Enabled	☐	☐
9.3	Ensure TCSS application protection switch is 'Turn on'	☐	☐
9.4	Ensure Container Asset has installed Container Security Agent	☐	☐
9.5	Ensure Scheduled Image Scanning is Configured	☐	☐
9.6	Ensure Automatic Cluster Check is ‘Enabled’	☐	☐
9.7	Ensure Vulnerability Scanning is enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
9.9	Ensure Virus Scanning is Enabled	☐	☐
9.11	Ensure notification is enabled for all high-risk security activities	☐	☐
9.12	Ensure log analysis is enabled	☐	☐

Appendix: CIS Controls v8 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
	No unmapped recommendations to CIS Controls v8	☐	☐

Appendix: Change History

Date	Version	Changes for this version
11/12/2025	1.0.0	Initial release